

# Plataforma de Proctoring para Evaluaciones Remotas

Supervisión asistida por IA para evaluaciones universitarias a distancia, con detección en el navegador, revisión humana obligatoria y evidencia con cadena de custodia defendible.

---

NIVEL DE PROCTORING L2.5

700 ESTUDIANTES CONCURRENTES

SELF-HOSTED · SOBERANÍA DE DATOS

# Tabla de contenidos

---

## PARTE I · DISCOVERY DE NEGOCIO Y PRODUCTO

---

|                                                 |  |
|-------------------------------------------------|--|
| 1. Introducción y contexto                      |  |
| 2. Problemática del negocio                     |  |
| 3. Visión estratégica del proyecto              |  |
| 4. Alcance del sistema                          |  |
| B1. Stakeholders, gobernanza y RACI             |  |
| B2. Personas y user journeys                    |  |
| B3. Requerimientos funcionales y no funcionales |  |
| B4. Análisis competitivo y posicionamiento      |  |
| B5. Business case: TCO y retorno                |  |
| B6. Métricas de éxito y KPIs                    |  |
| B7. Supuestos, dependencias y restricciones     |  |

## PARTE II · ARQUITECTURA Y DISEÑO DEL SISTEMA

---

|                                     |  |
|-------------------------------------|--|
| 5. Filosofía arquitectónica         |  |
| 6. Flujo completo del sistema       |  |
| 7. Arquitectura técnica completa    |  |
| 8. Arquitectura del frontend        |  |
| 9. Arquitectura del backend         |  |
| 10. Inteligencia artificial         |  |
| 11. Verificación biométrica         |  |
| 12. Seguridad                       |  |
| 13. Modelo de amenazas y proctoring |  |

## PARTE III · OPERACIÓN, ESCALA E INFRAESTRUCTURA

---

|                                  |  |
|----------------------------------|--|
| 14. Observabilidad y operaciones |  |
| 15. Escalabilidad                |  |
| 16. Infraestructura y DevOps     |  |

## PARTE IV · PLANIFICACIÓN, RIESGOS Y COSTOS

---

|                          |  |
|--------------------------|--|
| 17. Roadmap del proyecto |  |
| 18. Riesgos del proyecto |  |

19. Costos y tradeoffs

20. Conclusión estratégica y recomendaciones futuras

## PARTE V · APÉNDICES TÉCNICOS

T1. Modelo de datos y entidades

T2. Contratos de API y canales WebSocket

T3. Diagramas de secuencia

T4. Architecture Decision Records (ADRs)

T5. Estrategia de calidad y plan de pruebas

T6. Runbooks y operación

T7. Gestión del cambio y adopción

T8. Glosario

## PARTE VI · RECOMENDACIONES DE IMPLEMENTACIÓN (ARGENTINA)

A1. Implementación en Argentina: marco legal y operativo

A2. Opciones de liveness (detección de prueba de vida)

A3. Tecnología necesaria para el funcionamiento esperado

A4. Análisis arquitectónico independiente y arquitectura recomendada

### CÓMO LEER ESTE DOCUMENTO

El documento está escrito para audiencias mixtas y organizado en seis partes. La **Parte I** es de negocio (apta para dirección y comités); las **Partes II–III** son técnicas; la **Parte IV** cubre planificación; la **Parte V** reúne apéndices de referencia; la **Parte VI** contiene las recomendaciones de implementación para Argentina (legal, liveness y tecnología). Los bloques "**En palabras simples**" (recuadro verde) traducen cada concepto técnico para lectores no técnicos. Las decisiones de arquitectura se acompañan siempre de su *por qué*, ventajas, tradeoffs y alternativas descartadas.

## PARTE I

# Discovery de negocio y producto

---

Contexto, problemática, visión, alcance, stakeholders, personas, requerimientos, análisis competitivo, business case, métricas de éxito y supuestos.

# 1. Introducción y contexto

---

*Por qué existe este proyecto, de dónde surge la necesidad y qué problema institucional concreto resuelve.*

## 1.1 Contexto general

La institución cliente es una universidad que históricamente ha operado evaluaciones presenciales con supervisión humana, y que necesita extender de forma **sostenida** —no como excepción transitoria— una parte de su oferta evaluativa al modo remoto. Las causas son estructurales: cohortes geográficamente distribuidas, modalidades híbridas que se han vuelto parte del modelo educativo, programas dirigidos a profesionales en actividad, contingencias logísticas, y un crecimiento de matrícula que excede la capacidad de las aulas físicas en los picos del calendario académico.

El requerimiento concreto es soportar **setecientos estudiantes rindiendo en simultáneo**, con una calidad de supervisión defendible institucionalmente, sin requerir un proctor humano por estudiante —lo que sería económica y operativamente inviable a esa escala— pero sin caer tampoco en una evaluación sin supervisión donde el fraude se normaliza.

## 1.2 Situación actual

En el modelo presencial, la presencia física del docente resolvía implícitamente varias funciones a la vez: confirmaba la identidad del estudiante, monitoreaba el comportamiento, controlaba el acceso a material no permitido y producía un testimonio humano confiable del desarrollo del examen. En remoto, ninguna de esas funciones ocurre automáticamente. Si la institución no las atiende de forma explícita, la evaluación remota se convierte en una evaluación sin supervisión, donde el fraude académico —sin ser inevitable— se vuelve estructuralmente más fácil y, eventualmente, normalizado.

## 1.3 Necesidad institucional

La integridad académica no es solo una cuestión de equidad entre estudiantes honestos y oportunistas: es un problema de **validez del título**. Si la institución no puede sostener que sus evaluaciones miden lo que pretenden medir, el valor del diploma se erosiona —primero entre empleadores y pares académicos, después en la propia comunidad universitaria—. Esa erosión es lenta, acumulativa y muy difícil de revertir una vez consolidada. La necesidad, por tanto, es proteger el valor probatorio de la evaluación remota a una escala y un costo sostenibles.

## 1.4 Problemas existentes

La institución ha evaluado cuatro respuestas posibles antes de llegar a esta propuesta, cada una con limitaciones reales:

### OPCIONES CONSIDERADAS POR LA INSTITUCIÓN

| OPCIÓN                                    | EN QUÉ CONSISTE                                                               | POR QUÉ NO ALCANZA                                                                                                                                    |
|-------------------------------------------|-------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Sistema de honor</b>                   | Examen remoto sin supervisión, apelando a la integridad del estudiante.       | Funciona para evaluaciones formativas, pero falla en evaluaciones sumativas donde la sanción (aprobar/desaprobar) depende del examen.                 |
| <b>Supervisión humana sincrónica</b>      | Un proctor observa por cámara a un grupo pequeño en vivo.                     | Máxima garantía pero costo prohibitivo: a ratios de 1:6–1:12, supervisar 700 personas exige 60–120 proctors coordinados por ventana.                  |
| <b>Plataforma comercial de IA</b>         | ProctorU, Honorlock, Respondus, ETS, Mettl, etc.                              | Costos por estudiante/examen que escalan con la matrícula; datos biométricos en infraestructura de terceros fuera del país; rigidez de configuración. |
| <b>Plataforma propia (esta propuesta)</b> | Arquitectura abierta, self-hosted, equipo que entiende el contexto académico. | Más costosa que comprar pero menos que la supervisión sincrónica; aporta soberanía y un activo institucional en lugar de un gasto recurrente.         |

## 1.5 Motivación del proyecto

La motivación es doble. Operacionalmente, dotar a la institución de una capacidad propia de supervisión remota a costo sostenible. Estratégicamente, construir un **activo institucional**: soberanía completa sobre datos sensibles, conocimiento desarrollado en visión por computadora, sistemas distribuidos y cumplimiento normativo, y la opción —no la promesa— de ofrecer la plataforma como servicio a otras instituciones del ecosistema regional en una fase posterior. El diseño multi-tenant es factible desde el inicio aunque no se active.

### EN PALABRAS SIMPLES

La universidad puede (a) confiar en el honor, (b) pagar muchísimos vigilantes humanos, (c) alquilar un servicio externo caro que guarda las caras de los alumnos en otro país, o (d) construir su propio sistema. Esta propuesta es la opción (d): cuesta más al principio, pero después es de la universidad, es más barato a largo plazo y los datos no salen de casa.

## 2. Problemática del negocio

---

*Los dolores concretos que el proyecto resuelve, expresados en términos de negocio antes que técnicos.*

### 2.1 Problemas de las evaluaciones remotas no supervisadas

Sin supervisión, la evaluación remota traslada al estudiante el control total sobre las condiciones del examen. Esto habilita suplantación de identidad, consulta de material no permitido, asistencia de terceros y uso de medios externos. El problema no es que el fraude sea inevitable, sino que el **costo de cometerlo cae a casi cero**, lo que rompe el supuesto de equidad sobre el que descansa la calificación.

### 2.2 Escalabilidad operativa

El cuello de botella estructural de cualquier solución basada en vigilancia humana es lineal: más estudiantes implican proporcionalmente más vigilantes. A 700 concurrentes, ese modelo se vuelve económicamente inviable y operativamente frágil (depende de disponer de decenas de personas entrenadas en cada ventana). El negocio necesita una solución cuyo costo marginal por estudiante adicional sea **cercano a cero**.

### 2.3 Integridad académica

La integridad académica es el activo que el proyecto protege. Su deterioro tiene un efecto de segundo orden: cuando los estudiantes perciben que el sistema premia las estrategias por encima del aprendizaje, el comportamiento honesto se desincentiva y el fraude se normaliza en cascada.

### 2.4 Costo de la supervisión manual

La supervisión humana exhaustiva no solo es cara: concentra la atención de personal calificado en observar mayoritariamente comportamiento normal. El sistema invierte esa lógica —la atención humana se reserva para las sesiones que efectivamente la requieren— elevando ratios de proctor a estudiante a 1:100 o 1:200.

### 2.5 Riesgos legales

El tratamiento de rostros y embeddings faciales es tratamiento de **datos biométricos**, categoría especialmente protegida bajo prácticamente todos los regímenes (GDPR art. 9, LGPD art. 11, Ley 25.326 art. 7, y equivalentes regionales). Un programa de proctoring mal diseñado expone a la institución a sanciones regulatorias, a incidentes de privacidad reputacionalmente costosos, y a apelaciones disciplinarias que no se sostienen ante una objeción seria sobre la evidencia.

### 2.6 Dependencia de plataformas externas

Comprar el servicio resuelve el problema operativo pero crea otro: dependencia de un proveedor cuyos cambios de política, precio, disponibilidad o titularidad escapan al control institucional. Si el proveedor es adquirido, sufre un incidente, cambia su pricing o discontinúa el servicio, la institución queda expuesta sobre datos especialmente sensibles que ya no controla.

## 2.7 Costos institucionales recurrentes

El modelo comercial de pricing por estudiante por examen escala linealmente con el volumen. Para una institución que evalúa miles de estudiantes mensualmente, esto convierte el proctoring en un costo creciente y permanente, en lugar de una inversión amortizable.

### SÍNTESIS DEL PROBLEMA

El negocio enfrenta un dilema de tres vértices —costo, soberanía y escala— que ninguna de las opciones de mercado resuelve simultáneamente para el caso de uso académico interno. El proyecto se justifica precisamente por resolver los tres a la vez.



### 3. Visión estratégica del proyecto

Qué se construye, qué principios lo orientan y qué beneficios se esperan.

#### DECLARACIÓN DE VISIÓN

*Una plataforma propia de supervisión de evaluaciones remotas que permita a la institución sostener su oferta evaluativa a distancia con integridad académica defendible, costos sostenibles, soberanía de datos y respeto por los derechos de los estudiantes, sin replicar las limitaciones de los sistemas comerciales y sin depender de proveedores externos sobre los cuales no tiene control.*

#### 3.1 Objetivos estratégicos

Cuatro principios orientan cada decisión del proyecto, y conviene enunciarlos porque explican decisiones técnicas que de otro modo parecerían arbitrarias:

##### PRINCIPIOS ESTRATÉGICOS RECTORES

| PRINCIPIO                                      | QUÉ SIGNIFICA EN CONCRETO                                                                                                                                                                                        |
|------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Integridad académica defendible</b>         | La evidencia sostiene procesos disciplinarios apelados, no por la palabra del operador sino por una cadena criptográfica verificable. El nivel de garantía es explícito y honesto, sin pretender ser inviolable. |
| <b>Costos sostenibles</b>                      | La inversión inicial y el costo anual son compatibles con la realidad presupuestaria y se mantienen estables aunque el volumen crezca, sin pricing que escale exponencialmente con el uso.                       |
| <b>Soberanía de datos</b>                      | Ningún dato sensible (rostros, embeddings, evidencia, casos) sale de la infraestructura institucional sin decisión explícita y justificada.                                                                      |
| <b>Respeto por los derechos del estudiante</b> | Cumplimiento normativo nativo, transparencia sobre qué se monitorea, derechos del titular como funcionalidad, minimización de datos por defecto.                                                                 |

#### 3.2 Soberanía tecnológica

El despliegue self-hosted y la arquitectura abierta colocan a la institución como propietaria del sistema y de los datos. La capa de aplicación abstrae el almacenamiento (MinIO o S3) y la identidad (Keycloak federado con el directorio institucional), de modo que la institución no queda atada a ninguna nube concreta. La soberanía no es un eslogan: es una propiedad arquitectónica que se materializa en dónde viven los binarios de evidencia y quién controla las claves criptográficas.

#### 3.3 Privacidad por diseño

La privacidad es un principio transversal, no un módulo. El sistema **no transmite video continuo**: los pixels de la cámara permanecen en el dispositivo del estudiante salvo clips puntuales asociados a eventos. Esto minimiza la recolección, reduce el ancho de banda y, no por casualidad, es lo que hace viable la escala objetivo.

### 3.4 Escalabilidad y control institucional

La escala de 700 concurrentes se alcanza desplazando el cómputo al borde (al navegador del estudiante) en lugar de centralizar inferencia de video. El control institucional se preserva manteniendo la decisión disciplinaria siempre en manos humanas: el sistema asiste, no decide.

### 3.5 Lo que la visión deliberadamente NO es

#### HONESTIDAD ARQUITECTÓNICA — EXPECTATIVAS REALISTAS

La visión **no** es construir un sistema que prevenga el fraude de manera absoluta: eso es imposible en el paradigma web, donde el código corre en máquinas no controladas. La visión es **detectar** comportamientos anómalos con calidad razonable, **producir evidencia defendible** cuando los detecta, elevar el costo del fraude para la mayoría de los oportunistas, y permitir actuar disciplinariamente con respaldo. Confundir "prevención absoluta" con "detección con evidencia" es la causa más común de proyectos de proctoring que decepcionan a su institución.

La visión tampoco es reemplazar el juicio humano, ni entregar un sistema que se opere solo, ni entregar la versión definitiva en la primera iteración.

### 3.6 Beneficios esperados

- **Operacionales:** capacidad de sostener evaluaciones remotas a escala sin multiplicar personal de vigilancia.
- **Económicos:** costo marginal por estudiante cercano a cero; ausencia de cuotas recurrentes por estudiante/examen.
- **Legales:** cumplimiento normativo nativo y evidencia que resiste apelaciones.
- **Estratégicos:** activo institucional reutilizable, conocimiento interno y opción de expansión multi-institucional.

## 4. Alcance del sistema

La frontera explícita entre lo que el sistema hace, lo que no hace, y qué queda en manos humanas. Esta sección es el corazón de la "honestidad arquitectónica" del proyecto.

### 4.1 Qué hace el sistema

El sistema cubre el **ciclo completo de una evaluación supervisada**: configuración pre-examen, verificación de identidad biométrica, monitoreo continuo en el navegador, generación de eventos y evidencia, supervisión humana en vivo, y revisión humana asíncrona posterior con derivación a proceso disciplinario cuando corresponde.

### 4.2 Qué NO hace el sistema

#### EXCLUSIONES DELIBERADAS DEL ALCANCE

| EL SISTEMA NO...                              | POR QUÉ / CONSECUENCIA                                                                                                                                             |
|-----------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| opera el examen mismo                         | La interfaz de preguntas y respuestas es del LMS de la institución; el proctoring se integra (iframe, LTI o flujo coordinado) pero no se acopla a un LMS concreto. |
| califica las respuestas                       | La corrección y la nota son del LMS o del docente. El proctoring informa sobre la <i>integridad del proceso</i> , no sobre la calidad académica.                   |
| toma decisiones disciplinarias                | Flaggea, documenta y pone a disposición. La sanción es siempre humana. Sancionar automáticamente generaría falsos positivos masivos con consecuencias graves.      |
| transmite video continuo al servidor          | Los pixels permanecen en el dispositivo salvo clips puntuales. Preserva privacidad, reduce ancho de banda y habilita la escala.                                    |
| instala software en la máquina del estudiante | Corre íntegramente en el navegador. Simplifica la adopción pero limita el anti-tampering posible, lo que se reconoce explícitamente.                               |
| detecta medios externos no observables        | Una segunda computadora fuera de cuadro, un celular en la cintura o auriculares con un cómplice no se capturan directamente; solo heurísticamente y post-examen.   |
| sirve para certificaciones de alto impacto    | El nivel L2.5 corresponde a evaluaciones académicas internas, no a exámenes con consecuencias legales externas mayores.                                            |
| incluye servicios humanos del proveedor       | Proctors, revisores y coordinadores son personal de la institución. Es una plataforma propia, no un servicio tercerizado.                                          |

### 4.3 Responsabilidades humanas

El sistema depende de capacidades humanas que la institución debe proveer. La más subestimada es la **revisión humana asíncrona**: se estima que entre el 5% y el 15% de las sesiones requerirán revisión, lo que para 700 estudiantes implica entre 30 y 100 sesiones por examen, a 10–20 minutos cada una. Sin este recurso, el sistema técnicamente excelente falla, porque la evidencia se acumula sin que nadie la mire.

## 4.4 Límites del paradigma web

### EL LÍMITE INELUDIBLE

El cliente corre en una máquina del adversario y es, por definición, inspeccionable y manipulable. Las medidas de anti-tampering elevan el costo del bypass desde "trivial con DevTools" hasta "requiere conocimiento técnico medio-alto", suficiente para disuadir al 80–90% de los oportunistas y generar evidencia forense cuando un adversario más sofisticado lo intenta —pero no lo eliminan. Este límite se acepta formalmente en el Acuerdo de Nivel de Proctoring firmado *antes* del desarrollo.

## B1. Stakeholders, gobernanza y RACI

Quién participa, qué le importa, qué se le pide, y cómo se decide. Un proyecto de proctoring fracasa más por desalineación de stakeholders que por fallas técnicas.

### B1.1 Mapa de stakeholders

#### STAKEHOLDERS, INTERESES Y COMPROMISO REQUERIDO

| STAKEHOLDER                                                                    | QUÉ LE IMPORTA                                                                                                                        | QUÉ SE LE PIDE                                                                                                    |
|--------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <b>Patrocinadores institucionales</b><br>(rectorado, vicerrectorado académico) | Que resuelva un dolor real, costo predecible y proporcional, sin riesgo reputacional desproporcionado, alineado a la estrategia.      | Respaldo público, decisión sobre cuestiones estratégicas escaladas, disponibilidad para hitos de revisión.        |
| <b>Dirección académica operacional</b><br>(decanos, directores, coordinadores) | Soporte a calendarios sin fricciones, docentes sin carga extra, procesos disciplinarios manejables, adaptabilidad a sus evaluaciones. | Definir las políticas académicas que el sistema implementa (qué se supervisa, umbrales, procesos disciplinarios). |
| <b>Coordinación operativa del proctoring</b><br>(rol nuevo en producción)      | Herramientas para su trabajo, capacitación, canales de escalación claros.                                                             | Designación formal antes de Fase 1, capacitación, sostener la operación rutinaria, feedback continuo.             |
| <b>Estudiantes</b>                                                             | Proceso justo, sin fricción excesiva, respeto a su privacidad y derechos, sin acusaciones injustas.                                   | Consentimiento informado, cumplir el perfil mínimo de dispositivo.                                                |
| <b>Área legal y protección de datos</b>                                        | Cumplimiento normativo, bases legales correctas, DPIA, gestión de derechos del titular.                                               | Completar el DPIA, validar bases legales, revisar el Acuerdo de Nivel de Proctoring.                              |
| <b>Dirección de tecnología (TI)</b>                                            | Integración con identidad y LMS, operabilidad, seguridad, encaje en su infraestructura.                                               | Provisión de infraestructura, integración SAML/LDAP, integración con el LMS.                                      |
| <b>Equipo de implementación</b><br>(proveedor / interno)                       | Claridad de alcance, estabilidad de requisitos, acceso a stakeholders.                                                                | Construir, operar, documentar, mantener honestidad arquitectónica.                                                |

### B1.2 Matriz RACI de decisiones clave

R = Responsable (ejecuta) · A = Aprobador (rinde cuentas) · C = Consultado · I = Informado.

#### RACI — DECISIONES Y ENTREGABLES PRINCIPALES

| DECISIÓN / ENTREGABLE        | PATROC. | DIR. ACAD. | COORD. OP. | LEGAL/DPO | TI | EQUIPO IMPL. |
|------------------------------|---------|------------|------------|-----------|----|--------------|
| Aprobar inicio y presupuesto | A       | C          | I          | C         | C  | I            |

| DECISIÓN / ENTREGABLE                     | PATROC. | DIR. ACAD. | COORD. OP. | LEGAL/DPO | TI  | EQUIPO IMPL. |
|-------------------------------------------|---------|------------|------------|-----------|-----|--------------|
| Acuerdo de Nivel de Proctoring            | A       | C          | I          | R         | C   | R            |
| DPIA (análisis de impacto)                | I       | C          | I          | A/R       | C   | C            |
| Políticas académicas (umbrales, procesos) | I       | A/R        | C          | C         | I   | C            |
| Arquitectura técnica (ADRs)               | I       | I          | I          | C         | C   | A/R          |
| Integración identidad / LMS               | I       | I          | I          | I         | A/R | R            |
| Operación y on-call                       | I       | I          | C          | I         | C   | A/R          |
| Revisión de sesiones flaggeadas           | I       | A          | R          | I         | I   | I            |
| Decisión disciplinaria final              | I       | A/R        | C          | C         | I   | I            |

### B1.3 Estructura de gobernanza

El proyecto se gobierna mediante tres instancias con cadencias distintas: un **Comité de Dirección** (estratégico, trimestral, aprueba cambios de alcance mayores y presupuesto), un **Comité Técnico** (mensual, valida decisiones arquitectónicas y revisa riesgos), y la **coordinación operativa** (diaria/semanal, sostiene la operación). Todas las decisiones, minutas, ADRs y postmortems viven en un registro documental único que es activo institucional.

## B2. Personas y user journeys

Los usuarios reales del sistema, sus objetivos y su recorrido, para anclar las decisiones de diseño en necesidades concretas.

### B2.1 Personas

#### Soffía — Estudiante (22)

Cursa a distancia, rinde desde su notebook en casa. **Objetivo:** rendir sin fricción ni ansiedad.

**Frustraciones:** miedo a ser acusada injustamente, conexión inestable, instrucciones confusas.

**Necesita:** inicio rápido, claridad sobre qué se monitorea, soporte si algo falla.

#### Martín — Proctor en vivo (35)

Personal académico que supervisa exámenes. **Objetivo:** atender solo lo que requiere atención sin observar a 700 personas. **Frustraciones:** avalanchas de alertas irrelevantes. **Necesita:** panel que priorice por riesgo, alertas accionables, capacidad de intervenir.

#### Lucía — Revisora académica (44)

Revisa sesiones flaggeadas después del examen. **Objetivo:** decidir con criterio y evidencia sólida.

**Frustraciones:** evidencia incompleta o ambigua, falta de contexto. **Necesita:** línea de tiempo, clips, re-inferencia y audit log en una vista.

#### Diego — Coordinador operativo (39)

Opera el programa de proctoring. **Objetivo:** que los exámenes corran sin incidentes y la cola de revisión no se acumule. **Necesita:** asignar proctors, monitorear backlog, escalar a TI.

#### Ana — Oficial de protección de datos (50)

Responsable del cumplimiento. **Objetivo:** que el tratamiento sea legal y los derechos del titular se cumplan. **Necesita:** DPIA, registro de solicitudes, retención automática, eliminación verificable.

#### Pablo — Administrador del sistema (33)

Opera la plataforma técnicamente. **Objetivo:** disponibilidad y recuperabilidad. **Necesita:** observabilidad rica, runbooks, despliegues seguros, backups probados.

## B2.2 Journey del estudiante (extremo a extremo)

```
ANTES  recibe aviso del examen → verifica requisitos de dispositivo → (ansiedad: "¿y si falla?")
|
INICIO login institucional → consentimiento informado → permisos cámara/mic/pantalla
|                                     (fricción mínima, lenguaje claro)
▼
IDENTIDAD captura video → liveness → comparación facial → ✓ habilitado
|                                     (si falla: 2 reintentos → escala a proctor, no abort)
▼
EXAMEN  rinde en el LMS mientras el detector corre en su navegador (no intrusivo)
|                                     eventos y heartbeats van al backend; pixels NO salen del dispositivo
▼
CIERRE  envía respuestas → sesión finaliza → (si flaggeada) entra a revisión humana
|
DESPUÉS derecho de acceso/rectificación/eliminación disponibles desde la app
```

## B2.3 Journey del revisor académico

```
COLA    abre la cola ordenada por score de riesgo (mayor primero)
▼
CONTEXTO toma una sesión → ve línea de tiempo de eventos + clips firmados + observaciones
|                                     + output de re-inferencia + audit log (cada acceso queda registrado)
▼
JUICIO   pondera contexto humano (iluminación, patrón, severidad correlacionada)
▼
DECISIÓN descartar (falso positivo) | escalar (investigar) | derivar (disciplina)
|
TRAZA    decisión + fundamento se persisten vinculados a la evidencia (inmutable)
```



## B3. Requerimientos funcionales y no funcionales

El alcance funcional concreto (122 historias en 16 épicas se sintetizan aquí en requerimientos numerados y trazables) y los atributos de calidad exigidos.

### B3.1 Requerimientos funcionales (FR)

#### REQUERIMIENTOS FUNCIONALES POR DOMINIO

| ID    | REQUERIMIENTO                    | DESCRIPCIÓN                                                                                                           | FASE     |
|-------|----------------------------------|-----------------------------------------------------------------------------------------------------------------------|----------|
| FR-01 | Configuración de examen          | El admin crea exámenes, asigna estudiantes habilitados, define parámetros de monitoreo y carga la foto de referencia. | Fase 1   |
| FR-02 | Autenticación federada           | El estudiante ingresa con credenciales institucionales vía Keycloak (SAML/LDAP).                                      | Fase 1   |
| FR-03 | Consentimiento informado         | Flujo de consentimiento con texto versionado; acuse persistido con timestamp y hash.                                  | Fase 1   |
| FR-04 | Verificación biométrica          | Captura + liveness + embedding + comparación 1:1; 2 reintentos; escala a proctor al 3.º fallo.                        | Fase 1   |
| FR-05 | Verificación silenciosa continua | Comparación periódica del rostro contra el embedding inicial durante el examen.                                       | Fase 1   |
| FR-06 | Detección de comportamiento      | Rostro ausente, múltiples rostros, mirada, postura, pestaña/foco, monitores adicionales.                              | Fase 1   |
| FR-07 | Generación de eventos            | Eventos estructurados versionados con severidad y firma; reglas de transición configurables.                          | Fase 1   |
| FR-08 | Captura de evidencia             | Clip ante evento severo; hash+firma cliente; subida por URL firmada.                                                  | Fase 1   |
| FR-09 | Cadena de custodia               | Re-hash y firma backend, re-inferencia server-side, firma maestra, audit log inmutable.                               | Fase 1   |
| FR-10 | Cálculo de score de riesgo       | Score incremental ponderado por severidad, frecuencia y persistencia.                                                 | Fase 1   |
| FR-11 | Panel de supervisión en vivo     | Estado de sesiones, alertas en tiempo real, mensajería al estudiante, observaciones, cierre forzado.                  | Fase 1   |
| FR-12 | Cola de revisión asíncrona       | Sesiones flaggeadas ordenadas por score; vista de contexto; decisiones terminales.                                    | Fase 1   |
| FR-13 | Derechos del titular             | Acceso, rectificación, eliminación y portabilidad desde la aplicación.                                                | Fase 1–2 |
| FR-14 | Retención automática             | Aplicación de políticas de retención y eliminación; holds por casos abiertos.                                         | Fase 1–2 |
| FR-15 | Reportes y analytics             | Reportes por examen, por estudiante, distribuciones, exports, métricas de calidad del detector.                       | Fase 2   |

| ID    | REQUERIMIENTO     | DESCRIPCIÓN                                                                | FASE   |
|-------|-------------------|----------------------------------------------------------------------------|--------|
| FR-16 | Análisis de audio | Detección de voces múltiples (diferido por privacidad).                    | Fase 2 |
| FR-17 | Integración LMS   | Embedding/LTI/flujo coordinado con el sistema de evaluación institucional. | Fase 2 |
| FR-18 | Multi-tenancy     | Aislamiento por institución para oferta como servicio.                     | Fase 3 |

## B3.2 Requerimientos no funcionales (NFR)

### ATRIBUTOS DE CALIDAD Y OBJETIVOS CUANTITATIVOS

| ID     | ATRIBUTO                       | OBJETIVO                                                                        |
|--------|--------------------------------|---------------------------------------------------------------------------------|
| NFR-01 | Escalabilidad                  | 700 concurrentes sostenidos (hasta ~2.100 en picos multi-examen).               |
| NFR-02 | Disponibilidad                 | 99,9% en ventana de examen; 99,5% fuera de ventana.                             |
| NFR-03 | Latencia de detección          | Sub-segundo en cliente (p99).                                                   |
| NFR-04 | Latencia de propagación        | < 500 ms al panel (p99).                                                        |
| NFR-05 | Latencia de firma de evidencia | < 30 s desde la subida hasta la firma final.                                    |
| NFR-06 | Integridad de datos            | Cero pérdida de eventos confirmados y de evidencia.                             |
| NFR-07 | Recuperación                   | RTO 4 h (catastrófico) / 30 min (menor); RPO 5 min.                             |
| NFR-08 | Seguridad                      | TLS 1.3, cifrado at-rest, MFA para roles sensibles, audit log inmutable.        |
| NFR-09 | Privacidad                     | Minimización por defecto, sin video continuo, derechos del titular nativos.     |
| NFR-10 | Compatibilidad                 | Últimas 2 versiones de Chrome/Firefox/Edge/Safari; sin instalación.             |
| NFR-11 | Observabilidad                 | Métricas, logs estructurados y trazas en cada componente; dashboards y alertas. |
| NFR-12 | Mantenibilidad                 | Arquitectura por capas, twelve-factor, migrations versionadas, CI/CD.           |
| NFR-13 | Portabilidad                   | Abstracción de storage e identidad; self-hosted o cloud sin reescritura.        |
| NFR-14 | Accesibilidad y UX             | Bundle < 500 KB, inicio rápido, instrucciones claras, reducción de ansiedad.    |

## B3.3 Casos de uso con criterios de aceptación

### CASOS DE USO PRINCIPALES (FORMATO GHERKIN RESUMIDO)

| CASO DE USO                      | FLUJO Y CRITERIO DE ACEPTACIÓN                                                                                                                                                                                                                                                                                                                                   |
|----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>UC-01</b> Verificar identidad | <i>Dado</i> un estudiante con foto de referencia cargada, <i>cundo</i> captura su video y supera liveness, <i>entonces</i> el sistema compara el embedding y habilita el examen si la distancia < umbral. <i>Criterio:</i> ≤3 intentos; al 3.º fallo se genera evento crítico y se escala a proctor; el clip y el embedding se persisten con cadena de custodia. |

| CASO DE USO                                   | FLUJO Y CRITERIO DE ACEPTACIÓN                                                                                                                                                                                                                                                  |
|-----------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>UC-02</b> Detectar segunda persona         | <i>Dado un examen en curso, cuando se detectan <math>\geq 2</math> rostros durante N fotogramas, entonces se emite un evento de severidad alta, se captura evidencia y se alerta al proctor. Criterio: la evidencia queda firmada y la alerta llega al panel en &lt;500 ms.</i> |
| <b>UC-03</b> Resistir corte de red            | <i>Dado un corte de conectividad &lt;5 min, cuando el cliente reconecta, entonces reenvía los eventos del buffer en orden sin pérdida ni duplicación. Criterio: cortes &gt;5 min generan evento crítico al reconectar.</i>                                                      |
| <b>UC-04</b> Revisar sesión flaggeada         | <i>Dado un examen finalizado, cuando una sesión supera el umbral, entonces entra a la cola ordenada por score y el revisor emite una decisión terminal. Criterio: cada acceso a evidencia se registra en el audit log con propósito declarado.</i>                              |
| <b>UC-05</b> Ejercer derecho al olvido        | <i>Dado un estudiante sin casos abiertos, cuando solicita eliminación, entonces el sistema elimina binarios y embeddings y anonimiza registros, conservando un registro residual sin datos personales. Criterio: respuesta en plazo legal; verificable en auditoría.</i>        |
| <b>UC-06</b> Verificar evidencia en apelación | <i>Dado un caso disciplinario apelado, cuando se cuestiona la evidencia, entonces el sistema genera un certificado de verificación de la cadena de firmas. Criterio: un perito externo puede validar la cadena independientemente.</i>                                          |

## B4. Análisis competitivo y posicionamiento

Cómo se compara la plataforma propia con las alternativas de mercado, y por qué el caso de uso académico interno justifica construir.

### B4.1 Panorama de soluciones

#### COMPARATIVA CON ALTERNATIVAS DE MERCADO

| DIMENSIÓN                   | COMERCIALES DE IA<br>(PROCTORU, HONORLOCK,<br>RESPONDUS...) | SUPERVISIÓN HUMANA<br>SINCRÓNICA | PLATAFORMA PROPIA<br>(ESTA PROPUESTA) |
|-----------------------------|-------------------------------------------------------------|----------------------------------|---------------------------------------|
| Modelo de costo             | Por estudiante/examen (escala con volumen)                  | Por proctor-hora (muy alto)      | Inversión + costo fijo de operación   |
| Soberanía de datos          | Limitada (datos en terceros, a veces fuera del país)        | Alta                             | Total (self-hosted)                   |
| Adaptabilidad               | Restringida al mercado del proveedor                        | Alta pero no escalable           | Total                                 |
| Escala a 700                | Sí                                                          | Inviabile (60–120 proctors)      | Sí                                    |
| Defensibilidad de evidencia | Variable según proveedor                                    | Testimonial                      | Criptográfica + revisión humana       |
| Dependencia de proveedor    | Alta (lock-in)                                              | Media                            | Nula                                  |
| Time-to-market              | Inmediato                                                   | Inmediato                        | 12–18 meses                           |

### B4.2 Posicionamiento

El sistema no compite en "máxima garantía absoluta" (ese terreno es de L4/L5 y las certificaciones de alto impacto) ni en "inmediatez de compra". Compite en un nicho preciso y deliberado: **evaluaciones académicas universitarias regulares, a escala, con soberanía de datos y costo sostenible**. En ese cuadrante, la combinación de proctoring híbrido L2.5 + self-hosting + honestidad arquitectónica no tiene equivalente directo en las opciones comerciales.

## B5. Business case: TCO y retorno

El análisis económico que sustenta construir en lugar de comprar, con un modelo ilustrativo de costo total de propiedad a cinco años.

### NOTA METODOLÓGICA

Las cifras siguientes son **ilustrativas y paramétricas**: muestran la *estructura* y los *órdenes de magnitud relativos* del análisis, no un presupuesto cerrado. Los valores absolutos deben completarse con los costos reales de infraestructura, salarios y pricing vigente al momento de la decisión institucional. El propósito es comparar la forma de las curvas de costo, no fijar montos.

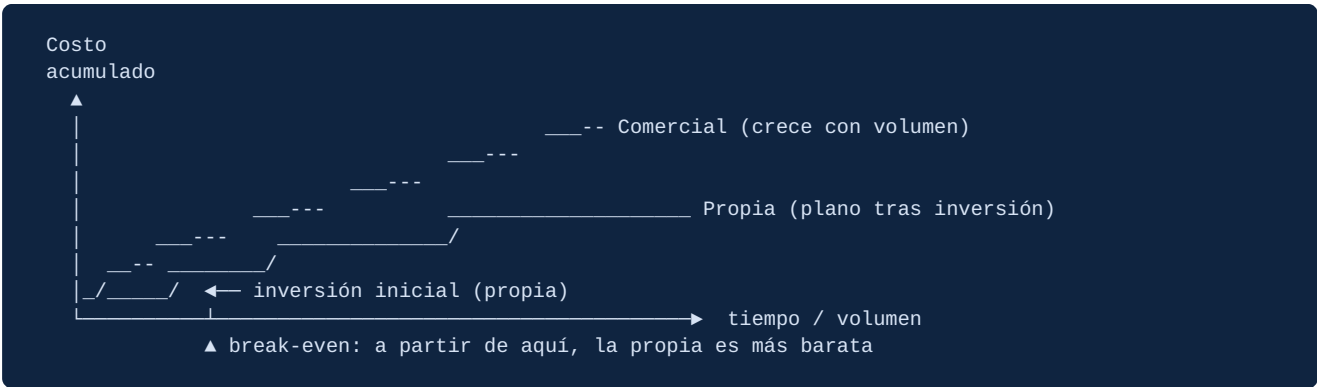
### B5.1 Estructura de costos comparada

#### COMPONENTES DE COSTO A 5 AÑOS (ESTRUCTURA ILUSTRATIVA)

| COMPONENTE                           | PLATAFORMA COMERCIAL            | PLATAFORMA PROPIA                          |
|--------------------------------------|---------------------------------|--------------------------------------------|
| Costo inicial (desarrollo)           | Nulo / bajo (setup)             | Alto (Fases 0–1)                           |
| Costo variable por estudiante/examen | <b>Creciente con el volumen</b> | ~0 (costo marginal cercano a cero)         |
| Infraestructura                      | Incluida en la cuota            | Fija y predecible (3–5 servidores)         |
| Operación y mantenimiento            | Incluida                        | Equipo propio (costo recurrente principal) |
| Revisión humana                      | Opcional / costo adicional      | Personal institucional                     |
| Riesgo de cambio de precio           | Alto (fuera de control)         | Nulo                                       |

### B5.2 La dinámica clave: curvas de costo

La diferencia decisiva no está en el punto inicial sino en la **pendiente**. El costo de la plataforma comercial crece con cada estudiante y cada examen; el de la plataforma propia es esencialmente plano una vez amortizada la inversión. Existe un **punto de cruce** (break-even) a partir del cual la plataforma propia es más barata en términos acumulados, y para una institución que evalúa miles de estudiantes mensualmente ese cruce ocurre dentro del horizonte de cinco años.



### B5.3 Valor no financiero

El análisis estrictamente financiero subestima el caso. La plataforma propia aporta **soberanía** sobre datos biométricos, **adaptabilidad** total, **independencia** de decisiones de proveedores, **conocimiento institucional** en dominios valiosos (visión por computadora, sistemas distribuidos, cumplimiento), y la **opción estratégica** de ofrecer la plataforma a otras instituciones. Estos factores, difíciles de monetizar, inclinan la decisión más allá de lo que muestran los números.

## B6. Métricas de éxito y KPIs

Cómo se medirá si el proyecto cumple su propósito, en cuatro dimensiones: producto, operación, negocio y experiencia.

### INDICADORES DE ÉXITO POR DIMENSIÓN

| DIMENSIÓN                    | KPI                                               | OBJETIVO / DEFINICIÓN DE ÉXITO                                |
|------------------------------|---------------------------------------------------|---------------------------------------------------------------|
| Producto /<br>detección      | Tasa de falsos positivos (post-revisión)          | Tendencia decreciente tras calibración en Fase 2.             |
|                              | Cobertura de detección de vectores en alcance     | Eventos generados para los vectores declarados detectables.   |
|                              | Precisión de la verificación biométrica           | Falsos rechazos por debajo de umbral aceptable.               |
| Operación                    | Disponibilidad en ventana de examen               | ≥ 99,9%.                                                      |
|                              | Incidentes graves por trimestre                   | Por debajo del umbral acordado.                               |
|                              | Backlog de revisión humana                        | Sin acumulación sostenida; sesiones revisadas en plazo.       |
| Negocio                      | Costo por estudiante evaluado                     | Decreciente y por debajo de la alternativa comercial.         |
|                              | Volumen de exámenes sostenidos                    | Crecimiento sin que el proctoring sea un cuello de botella.   |
| Experiencia /<br>legitimidad | Satisfacción del estudiante                       | Medida formalmente; fricción y ansiedad percibidas bajas.     |
|                              | Casos disciplinarios que se sostienen al apelarse | Alta proporción confirmada; evidencia no impugnada con éxito. |
|                              | Incidentes de privacidad                          | Cero.                                                         |

#### LA PREGUNTA QUE DEFINE EL ÉXITO

Al cabo de un año de operación productiva: ¿puede la institución sostener su programa de evaluaciones remotas con confianza, a volumen significativo, sin que el proctoring sea un dolor recurrente, sin incidentes de privacidad, y con casos disciplinarios que se sostienen cuando se apelan? Si la respuesta es afirmativa, el proyecto cumplió su visión.

## B7. Supuestos, dependencias y restricciones

Lo que el proyecto asume como cierto, de qué depende para avanzar, y qué límites acepta. Hacer esto explícito permite revisar decisiones si un supuesto resulta falso, en lugar de descubrirlo en producción.

### B7.1 Supuestos

#### SUPUESTOS DEL PROYECTO Y SU IMPACTO SI FALLAN

| SUPUESTO                                                                                                            | IMPACTO SI RESULTA FALSO                                                                   |
|---------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| La institución dispone de fotos institucionales de calidad razonable de cada estudiante.                            | Sin foto de referencia, la verificación 1:1 no opera; requiere proceso de registro previo. |
| Los estudiantes acceden con dispositivos que cumplen el perfil mínimo (cámara, mic, navegador moderno, ≥10/2 Mbps). | Falsos positivos por hardware insuficiente; necesidad de degradación o escalación.         |
| La institución sostiene la capacidad de revisión humana asíncrona (5–15% de sesiones).                              | La evidencia se acumula sin revisión; el sistema falla en su propósito.                    |
| El equipo de operaciones tiene o adquiere conocimiento básico de Docker, Prometheus/Grafana y PostgreSQL.           | Incidentes mal gestionados; riesgo durante ventanas críticas.                              |
| El marco legal aplicable es el del país de la institución y de la mayoría de los estudiantes.                       | Estudiantes en jurisdicciones distintas (UE/Brasil) requieren análisis legal específico.   |
| El capacity model (cargas estimadas) es aproximadamente correcto.                                                   | Re-dimensionamiento; el monitoreo desde el día uno permite detectarlo a tiempo.            |

### B7.2 Dependencias

- **Integración de identidad:** el directorio institucional (Active Directory / LDAP / IdP SAML) debe estar disponible para la federación.
- **Integración con el LMS:** el sistema de evaluación debe permitir embedding/LTI o un flujo coordinado.
- **Infraestructura:** provisión de los 3–5 servidores (o equivalente cloud) por parte de TI.
- **Procesos institucionales:** firma del Acuerdo de Nivel de Proctoring y del DPIA antes de desarrollar.
- **Recursos humanos:** designación de coordinación operativa y revisores antes de la Fase 1.

### B7.3 Restricciones

#### RESTRICCIONES DEL PROYECTO

| TIPO                   | RESTRICCIÓN                                                                                 |
|------------------------|---------------------------------------------------------------------------------------------|
| Paradigma técnico      | Ejecución íntegra en navegador, sin instalación: limita el anti-tampering al nivel L2.5.    |
| Alcance de uso         | Solo evaluaciones académicas internas de impacto medio; no certificaciones de alto impacto. |
| Decisión disciplinaria | Siempre humana; el sistema nunca sanciona automáticamente.                                  |



| TIPO       | RESTRICCIÓN                                                                        |
|------------|------------------------------------------------------------------------------------|
| Privacidad | No hay transmisión de video continuo; solo clips puntuales.                        |
| Temporal   | Despliegues a producción solo fuera de ventanas de examen activo.                  |
| Legal      | Tratamiento de datos biométricos sujeto a base legal, DPIA y derechos del titular. |

## PARTE II

# Arquitectura y diseño del sistema

---

Filosofía arquitectónica, flujo completo, arquitectura técnica, frontend, backend, inteligencia artificial, biometría, seguridad y modelo de amenazas.

## 5. Filosofía arquitectónica

*Los cuatro principios de diseño de los que se derivan, en cascada, casi todas las decisiones técnicas posteriores.*

### 5.1 Client-heavy: desplazamiento del cómputo al borde

Toda inferencia de visión por computadora que pueda razonablemente correr en el navegador, corre ahí. **No es elegancia técnica, es necesidad económica:** procesar 700 streams de video de forma centralizada costaría entre 10 y 50 veces más y tendría una complejidad operacional desproporcionada. La consecuencia es que el backend nunca ve los pixels originales salvo en momentos puntuales, y opera sobre la interpretación que el cliente hace del video.

#### EN PALABRAS SIMPLES

En lugar de enviar el video de cada alumno a un servidor central que lo analice (carísimo), cada computadora analiza su propio video y solo envía "avisos" cortos: "rostro ausente", "dos personas detectadas". El servidor recibe avisos, no películas.

### 5.2 IA en el navegador

Los modelos de MediaPipe se ejecutan sobre WebAssembly y WebGL dentro de un Web Worker dedicado, lo que hace viable la detección local a 5–10 fotogramas por segundo sin bloquear la experiencia del estudiante ni requerir infraestructura central de inferencia.

### 5.3 Backend como verificador (desconfianza del cliente)

El cliente **nunca** es fuente de verdad sobre la integridad del examen. La evidencia que sube se trata como entrada potencialmente hostil: se re-analiza independientemente (re-inferencia server-side), se re-hashea y se firma con autoridad del backend, de modo que la versión confiable sea la del servidor, no la del estudiante. El cliente es un sensor con sesgos conocidos, no un componente confiable.

### 5.4 Event-driven y desacoplamiento

La comunicación entre componentes ocurre mediante eventos estructurados con esquema explícito y **versionado**. El cliente no llama métodos del servidor: emite eventos. El servidor no actualiza el panel del proctor directamente: publica eventos a los que el panel se suscribe. El procesamiento intensivo no se ejecuta sincrónicamente: se encola una tarea que un worker procesa cuando puede. Este patrón paga dividendos en escalabilidad horizontal, resiliencia ante fallas parciales y evolución independiente de componentes.

### 5.5 Observabilidad como ciudadano de primera clase

Cada evento, decisión automática, acceso humano a evidencia y estado anómalo es observable mediante métricas, trazas o logs. Operar sin observabilidad un sistema que sostiene 700 personas en una ventana crítica es "construir un avión sin instrumentos". Una funcionalidad no observable, no monitoreada ni recuperable, no se considera "lista".

## 5.6 Zero trust y revisión humana obligatoria

El sistema asume hostilidad en todas las capas: los datos del cliente pueden ser maliciosos, los usuarios autenticados pueden estar comprometidos, los componentes internos pueden tener vulnerabilidades. Sobre ese supuesto se aplica defensa en profundidad, mínimo privilegio y trazabilidad. Y por encima de todo, la decisión disciplinaria queda siempre sujeta a revisión humana: ninguna sanción es automática.

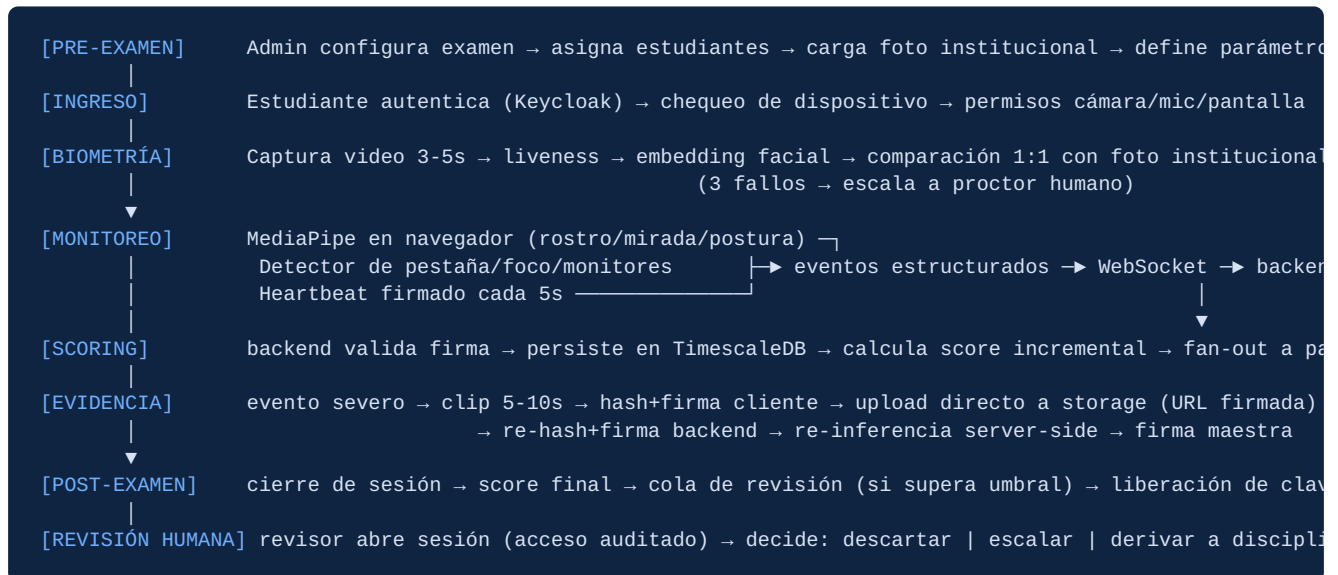
### COHERENCIA DEL DISEÑO

Cuando una decisión técnica de las secciones siguientes parezca contraintuitiva, casi siempre es la consecuencia directa de uno de estos cinco principios. Conviene volver a esta sección al leer las decisiones de backend, persistencia y mensajería.

## 6. Flujo completo del sistema

El recorrido extremo a extremo de un examen, desde la configuración previa hasta la revisión humana posterior, con diagramas conceptuales descritos en texto.

### 6.1 Vista general del ciclo



### 6.2 Pre-examen y configuración

Los administradores configuran el examen, asignan la lista de estudiantes habilitados, definen los parámetros de monitoreo aplicables (umbrales, detectores activos) y cargan la foto institucional de referencia si no estaba precomputada. La calendarización se carga con anticipación, lo que permite al equipo operacional saber de antemano cuándo estará bajo SLA estricto.

### 6.3 Autenticación

El estudiante ingresa con sus credenciales institucionales habituales (las mismas del LMS y el webmail) mediante federación SAML/LDAP a través de Keycloak. Recibe un token JWT y es redirigido al examen habilitado. La aplicación valida que el dispositivo cumple el perfil mínimo (cámara, micrófono, capacidad de cómputo, navegador compatible) y, si no, comunica el problema con instrucciones claras o escala a un proctor.

### 6.4 Biometría y consentimiento

Antes de habilitar el examen, el estudiante atraviesa: (1) un flujo de **consentimiento informado** —pantalla dedicada con lenguaje claro sobre qué se recolecta, cómo, dónde, por cuánto tiempo y sus derechos; el acuse se persiste con timestamp y hash—; y (2) la **verificación de identidad** en cuatro pasos: captura de video corto → liveness detection → cálculo de embedding facial → comparación por distancia coseno contra el embedding precomputado. Hasta dos reintentos; tres fallos escalan a un proctor humano.

## 6.5 Monitoreo y eventos

Durante el examen, el cliente ejecuta continuamente los modelos de MediaPipe sobre el feed local y un detector adicional analiza la pestaña activa, el foco de ventana y la presencia de múltiples monitores. Cada detección produce un evento estructurado que se almacena en un buffer circular local (IndexedDB, resistente a cortes) y se envía por WebSocket. Cada 5 segundos se envía un heartbeat firmado con HMAC. El backend valida cada firma, persiste, calcula score y propaga a los paneles.

## 6.6 Scoring y captura de evidencia

Los eventos no son binarios "fraude / no fraude": cada uno tiene una severidad que determina su tratamiento. Los de severidad baja se acumulan estadísticamente; los medios generan alerta moderada; los altos disparan captura automática de evidencia; los críticos requieren atención inmediata del proctor. El score de riesgo se calcula incrementalmente y ordena la cola de revisión posterior.

## 6.7 Post-examen y revisión humana

Al cerrar la sesión, una tarea asíncrona consolida métricas, calcula el score final y encola la sesión para revisión si supera el umbral. Los revisores académicos acceden mediante el panel —cada acceso se registra en el audit log— con todo el contexto disponible (evidencia, observaciones del proctor, output de re-inferencia, audit log de accesos) y emiten una de tres decisiones: **descartar** como falso positivo, **escalar** para investigación, o **derivar** a proceso disciplinario formal.

### EN PALABRAS SIMPLES

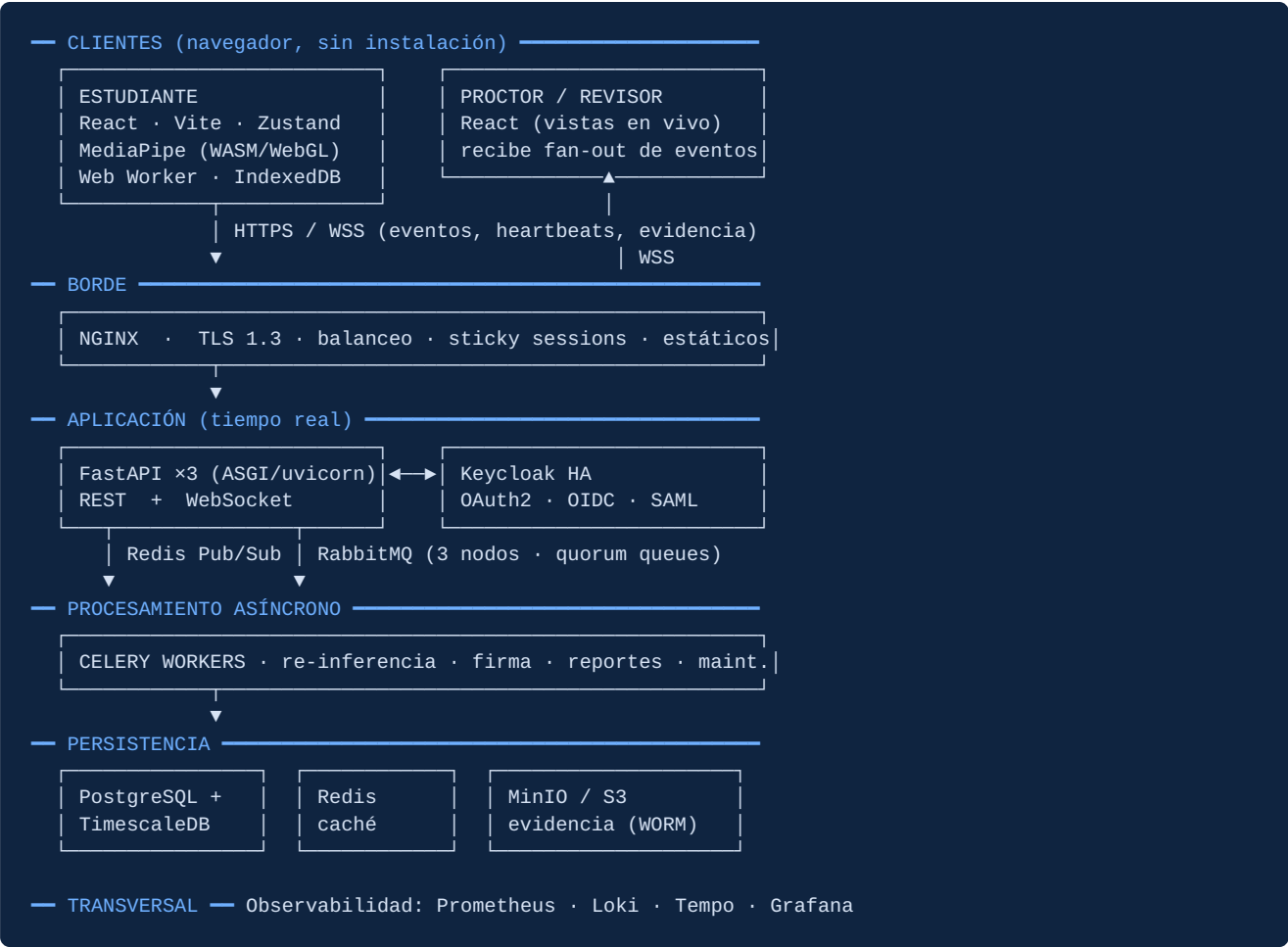
El sistema es como un detector de humo conectado a un bombero. El detector (la IA en el navegador) avisa cuando algo parece raro y saca una foto. Pero quien decide si hubo fuego de verdad —y qué hacer— es siempre una persona (el revisor), nunca la máquina.

## 7. Arquitectura técnica completa

La vista de componentes, el stack tecnológico, y —para cada decisión— el porqué, las ventajas, los tradeoffs y las alternativas descartadas.

### 7.1 Vista de componentes

El sistema se compone de tres planos —cliente, servidor en tiempo real, servidor asíncrono— soportados por una capa de persistencia y servicios transversales. El diagrama siguiente describe el flujo de arriba (cliente) hacia abajo (persistencia).



### 7.2 Decisiones tecnológicas: el porqué, ventajas y alternativas descartadas

#### STACK Y JUSTIFICACIÓN ARQUITECTÓNICA

| COMPONENTE | TECNOLOGÍA             | POR QUÉ / VENTAJA                                                                       | TRADEOFF · ALTERNATIVA DESCARTADA                        |
|------------|------------------------|-----------------------------------------------------------------------------------------|----------------------------------------------------------|
| Frontend   | React + Vite + Zustand | Madurez, talento disponible, builds rápidos, estado complejo sin la ceremonia de Redux. | Redux descartado por complejidad ceremonial innecesaria. |

| COMPONENTE         | TECNOLOGÍA                   | POR QUÉ / VENTAJA                                                                                                               | TRADEOFF · ALTERNATIVA DESCARTADA                                              |
|--------------------|------------------------------|---------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| IA en cliente      | MediaPipe (WASM/ WebGL)      | Optimizado para navegador, modelos pre-entrenados y validados, API coherente, tamaño razonable.                                 | TensorFlow.js directo o modelos custom: más esfuerzo y menos validación.       |
| API backend        | FastAPI (uvicorn/ASGI)       | Rendimiento I/O-bound, async nativo para miles de conexiones, OpenAPI automático, validación Pydantic, WebSockets maduros.      | Flask/Django: menor rendimiento async para este perfil de carga.               |
| Datos de dominio   | PostgreSQL                   | Consistencia transaccional estricta para usuarios, exámenes, sesiones, sanciones.                                               | —                                                                              |
| Series temporales  | TimescaleDB                  | Extensión de Postgres (no otra DB): hypertables, compresión 10–20×, agregados continuos.                                        | Postgres nativo: inserts se degradan, sin compresión, DELETE masivos costosos. |
| Caché / fan-out    | Redis                        | Caché de sesiones, Pub/Sub de baja latencia (<50 ms) para eventos no críticos, rate limiting.                                   | Como broker de tareas críticas: durabilidad insuficiente.                      |
| Mensajería crítica | RabbitMQ (quorum)            | Durabilidad real vía consenso Raft; un mensaje confirmado no se pierde ante caída de nodo.                                      | Complejidad adicional al stack; aceptada por el beneficio de durabilidad.      |
| Evidencia          | MinIO / S3 (Object Lock)     | WORM (Write Once Read Many) garantiza inmutabilidad durante la retención; abstracción que permite self-hosted o cloud.          | Filesystem plano: sin inmutabilidad ni cadena de custodia.                     |
| Identidad          | Keycloak (OAuth2/OIDC/ SAML) | Federación con el directorio institucional, MFA, gestión de roles; auth es un dominio donde implementar a mano es catastrófico. | Auth propia: riesgo de errores graves (session fixation, CSRF, tokens).        |

## 7.3 Persistencia y modelo de datos

PostgreSQL opera con **dos roles funcionales**: tablas transaccionales clásicas para las entidades de dominio (usuario, examen, sesión, evento, evidencia, score) y la extensión TimescaleDB que convierte la tabla de eventos en una *hypertable*. La *hypertable* particiona automáticamente los datos en *chunks* por día; los chunks recientes (7 días) quedan sin comprimir para consultas operacionales, los de 7 días a 1 año se comprimen (~10× menos disco), y los de más de 1 año se exportan a Parquet en almacenamiento de objetos y se eliminan de la base activa. Los *continuous aggregates* mantienen agregaciones materializadas (eventos por sesión por minuto, score por sesión, sesiones activas por examen) que reducen la latencia de los paneles en órdenes de magnitud. El esquema evoluciona con migrations versionadas (Alembic), aplicadas antes de exponer la nueva versión a tráfico, y las migrations destructivas se hacen en dos pasos para sobrevivir rollbacks.



## 7.4 Procesamiento asíncrono y validación de eventos

Como regla, todo lo que toma más de 100 ms o puede fallar transitoriamente se ejecuta de forma asíncrona con Celery sobre RabbitMQ. Dos tareas **no toleran pérdida** —la re-inferencia server-side y la firma criptográfica de evidencia— porque su pérdida abriría un agujero en la cadena de custodia. Las colas se separan por prioridad y tipo (`evidence_critical`, `reports`, `notifications`, `maintenance`, y los `dlx_*` de dead letters). Los workers usan `task_acks_late` y `prefetch_multiplier=1` para comportamiento predecible ante fallas, con reintentos por backoff exponencial (máx. 5) antes de pasar a la dead letter exchange para inspección humana.

## 8. Arquitectura del frontend

*El cliente es el componente más activo del sistema: ejecuta la IA, gestiona la captura multimedia y mantiene la sincronización con el backend.*

### 8.1 Capa de presentación: React, Vite, Zustand, Tailwind

React por madurez y talento; Vite por builds dramáticamente más rápidos que Webpack y mejor integración con módulos ES2020 (clave para cargar MediaPipe dinámicamente); Zustand por un balance entre simplicidad y capacidad sin la ceremonia de Redux; Tailwind por consistencia visual sin librerías pesadas que inflen el bundle. El objetivo de bundle inicial es **menos de 500 KB** de aplicación más los modelos cargados de forma diferida, porque el inicio del examen es un momento de ansiedad donde una espera larga afecta al estudiante.

### 8.2 MediaPipe sobre WebAssembly y WebGL

Los modelos no corren en el hilo principal sino en un **Web Worker dedicado**, comunicándose por transferencia de buffers de pixels (sin copias). WebAssembly aporta cómputo casi nativo en el navegador y WebGL acelera la inferencia en la GPU. Frecuencias objetivo: 5–10 fps para Face Detection y Face Mesh, 2–5 fps para Pose (más costoso). La detección de capacidad inicial ajusta la frecuencia o degrada gradualmente si el dispositivo es insuficiente.

#### EN PALABRAS SIMPLES

WebAssembly y WebGL son tecnologías que permiten que la página web haga cálculos pesados (como reconocer una cara) casi tan rápido como un programa instalado, usando la tarjeta gráfica. El "Web Worker" es como un ayudante en segundo plano: hace ese trabajo sin trabar la pantalla del alumno.

### 8.3 Captura multimedia y performance

El cliente gestiona cámara, micrófono y compartición de pantalla. El pipeline produce *eventos discretos* a partir de la inferencia continua aplicando reglas de transición de estado: la ausencia de rostro en un solo fotograma no es evento; lo es si se sostiene más de tres segundos. Esto evita falsos positivos por ruido instantáneo y es configurable por la institución.

### 8.4 Sincronización y resiliencia (buffer + reconexión)

Tres canales de comunicación: HTTPS para operaciones transaccionales, un WebSocket persistente para eventos/heartbeats/comandos, y subida directa de binarios al storage mediante URLs firmadas (para que los archivos pesados no pasen por el backend). Un buffer local en **IndexedDB** resiste cortes: si el WebSocket cae, los eventos se acumulan y se reenvían en orden al reconectar, con `last_event_id`. Un corte de hasta 5 minutos no genera pérdida; cortes más largos disparan un evento crítico al reconectar. La reconexión usa backoff exponencial con jitter del 20% para evitar el "thundering herd".

## 9. Arquitectura del backend

*El backend es relativamente pasivo —distribuye trabajo y se reserva lo que no puede confiarse al cliente— pero es el guardián de la verdad del sistema.*

### 9.1 FastAPI como núcleo

Cada instancia de FastAPI corre en un proceso uvicorn de un solo hilo asíncrono; no se usa multi-worker dentro de la instancia, sino que se escalan **horizontalmente múltiples instancias** detrás de Nginx. Esto simplifica la operación (métricas por proceso interpretables, fallas aisladas) y hace trivial la futura migración a Kubernetes (cada instancia ≈ un pod). El código sigue una arquitectura por capas (dominio, aplicación, infraestructura, presentación) inspirada en Clean/Hexagonal Architecture pero pragmáticamente adaptada: el dominio es puro y rico en comportamiento, la aplicación orquesta casos de uso, la infraestructura implementa los puertos abstractos (Postgres, Redis, RabbitMQ, MinIO), y la presentación es delgada.

### 9.2 REST y WebSockets

La API REST está versionada desde el día uno (`/api/v1/...`). Los canales WebSocket se organizan por rol: `/ws/student/session/{id}` (eventos y heartbeats del estudiante), `/ws/proctor/exam/{id}` (flujo en vivo para el panel del proctor) y `/ws/admin/system` (monitoreo con autorización elevada). El JWT se valida en cada request HTTP (firma contra la clave pública de Keycloak, expiración, audience, issuer) y, en WebSockets, en el handshake y periódicamente durante la sesión.

### 9.3 Transporte en tiempo real, sticky sessions y reconexión

Nginx termina TLS (1.3 preferido, HSTS con preload, OCSP stapling), balancea por round-robin con health checks para HTTP, y usa **sticky sessions** para WebSockets (cada cliente queda asignado a una instancia mientras dure la conexión). Esta decisión (ADR-0008) evita la complejidad de distribuir estado de WebSocket entre instancias. Sus consecuencias se gestionan explícitamente: *graceful shutdown* con modo drain y notificación de reconexión para los rolling deployments; monitoreo de distribución de conexiones contra concentración por azar de hash; y restauración automática de estado al caer una instancia, porque el estado que importa vive en TimescaleDB y Redis, no en memoria.

### 9.4 Celery, Redis y RabbitMQ: el doble plano de mensajería

#### PLANOS DE MENSAJERÍA Y SUS GARANTÍAS

| PLANO                  | TECNOLOGÍA                               | USO · GARANTÍA                                                                                                                                                                                                       |
|------------------------|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Tiempo real no crítico | Redis Pub/Sub                            | Fan-out de eventos hacia paneles (~<50 ms). La mayoría de los eventos. Pérdida tolerable.                                                                                                                            |
| Tiempo real crítico    | RabbitMQ (colas durables por supervisor) | Alertas que disparan acción inmediata (segunda persona, posible cambio de identidad). Al reconectar, la instancia drena la cola del supervisor antes de operar en Pub/Sub. Deduplicación por <code>event_id</code> . |
| Tareas asíncronas      | Celery sobre RabbitMQ (quorum)           | Re-inferencia, firma de evidencia, reportes, notificaciones, housekeeping. Acks tardíos; reintentos con backoff; dead letter exchanges.                                                                              |

## 9.5 Tareas principales del backend

- **Re-inferencia de evidencia:** descarga el clip, ejecuta modelos server-side (potencialmente más sofisticados que los del cliente), y compara con lo reportado. Una *discrepancia* es una señal forense de posible tampering. 1–10 s por clip.
- **Firma de evidencia:** recalcula el hash (si no coincide, evento crítico de "evidencia corrupta o manipulada") y firma con la clave maestra asimétrica del backend (RSA-2048 o Ed25519). Esta firma es lo que hace defendible la evidencia.
- **Generación de reportes post-examen:** sesiones flaggeadas ordenadas por score, distribución estadística para detectar outliers, sumario institucional, exports.
- **Notificaciones y tareas programadas:** avisos, rotación de claves de sesión, archivado de chunks, validación periódica de integridad de firmas.

## 10. Inteligencia artificial

*Qué modelos se usan, qué detectan realmente, y —con honestidad— qué no pueden detectar y por qué.*

### 10.1 Los tres detectores de MediaPipe

#### DETECTORES ACTIVOS DURANTE EL EXAMEN

| DETECTOR       | QUÉ PRODUCE                                     | PARA QUÉ SE USA                                                                                                                                    |
|----------------|-------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| Face Detection | Bounding boxes y score de confianza por rostro. | Detectar ausencia de rostro, múltiples rostros (otra persona en cuadro) y rostros de baja confianza (iluminación o posible video de mala calidad). |
| Face Mesh      | 468 landmarks faciales densos.                  | Estimar la dirección de la mirada (posición de los iris) y generar el embedding facial para la verificación silenciosa continua.                   |
| Pose           | Puntos clave del cuerpo.                        | Detectar posturas compatibles con consulta de material (inclinarse sostenidamente hacia un costado).                                               |

### 10.2 De inferencia continua a eventos discretos (heurísticas)

La IA no decide "fraude": produce señales que una capa de reglas convierte en eventos con severidad. Las reglas de transición de estado evitan falsos positivos por ruido (umbrales temporales, fotogramas consecutivos, patrones sostenidos). La mirada desviada es normal —los estudiantes piensan, miran al techo, recuerdan—; solo se vuelve evento cuando el patrón sugiere consulta sostenida hacia un punto fijo fuera de la pantalla.

### 10.3 Limitaciones reales y falsos positivos

#### NO SE VENDE HUMO

La detección es **inherentemente probabilística**. El estudiante puede memorizar y recitar lo que vio fuera de cámara. Una segunda computadora o un celular fuera de cuadro **no se detectan directamente**. El hardware de baja calidad y ciertas condiciones de iluminación generan falsos positivos. Por eso ninguna señal de IA aplica sanción automática: todas alimentan un score y un panel donde una persona pondera el contexto.

### 10.4 Inferencia local y optimización

La inferencia local es la decisión que hace viable la escala: 700 dispositivos haciendo cada uno su propio trabajo en lugar de un servidor central procesando 700 streams. La optimización combina frecuencias de muestreo moderadas, ejecución en Web Worker, transferencia de buffers sin copia, y degradación graceful en dispositivos limitados (primero baja Pose, luego Face Mesh, y solo si es insuficiente se aborta y escala a proctor).

# 11. Verificación biométrica

*Cómo se confirma que quien rinde es quien dice ser, y cómo se gestionan los riesgos y la privacidad de un dato especialmente sensible.*

## 11.1 El flujo de verificación en cuatro pasos

- 1. **Captura:** video corto (3–5 s) del estudiante, con instrucciones claras.
- 2. **Liveness:** se confirma que es una persona viva, no una foto. Señales: parpadeo natural involuntario, micro-movimientos faciales, y profundidad estimada por la geometría 3D de Face Mesh. Sin liveness, el bypass sería trivial (mostrar una foto del compañero).
- 3. **Embedding:** sobre el video válido se calcula un vector numérico (típicamente 128–512 dimensiones) que representa rasgos distintivos del rostro.
- 4. **Comparación 1:1:** distancia coseno contra el embedding precomputado de la foto institucional. Si está bajo el umbral, verificación exitosa.

## 11.2 Umbrales, reintentos y verificación silenciosa continua

El umbral se configura **conservadoramente**: rechazar a un estudiante legítimo es peor que aceptar a un impostor en este paso, porque el impostor aún debe superar la verificación continua y el estudiante rechazado pierde tiempo y gana ansiedad. Hasta dos reintentos; tres fallos generan un evento crítico que escala a un proctor. Durante todo el examen, la **verificación silenciosa continua** compara el embedding del rostro detectado en cada inferencia contra el inicial; una desviación significativa dispara un evento crítico de "posible cambio de identidad".

## 11.3 Persistencia, riesgos biométricos y privacidad

El flujo persiste dos artefactos: el clip de verificación (con la misma cadena de custodia que cualquier evidencia) y el embedding (cifrado, para la verificación continua). Los riesgos se gestionan explícitamente:

### RIESGOS BIOMÉTRICOS Y MITIGACIONES

| RIESGO                                                    | MITIGACIÓN                                                                                                                    |
|-----------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| Liveness bypaseable con video pregrabado de calidad       | Aceptado como límite del paradigma cliente; combinado con verificación continua y revisión humana.                            |
| Estudiantes sin foto institucional limpia                 | Proceso de registro previo gestionado por la institución como prerequisite.                                                   |
| Falsos negativos (rechazo de legítimos)                   | Umbrales conservadores, dos reintentos, escalación a proctor.                                                                 |
| Embeddings como datos personales especialmente protegidos | Cifrado at-rest, retención específica, eliminación al egreso del estudiante, consentimiento informado y derechos del titular. |

#### **EN PALABRAS SIMPLES**

Un "embedding" es como un código numérico único que resume una cara, parecido a una huella digital matemática. No es la foto; es un vector de números. Se guarda cifrado, se usa solo para confirmar identidad, y se borra cuando el estudiante deja la institución.

## 12. Seguridad

*El modelo de seguridad, la gestión de identidad, y la cadena de custodia que convierte la evidencia en defendible.*

### 12.1 Modelo de seguridad y threat model de seguridad

La seguridad se construye en capas asumiendo que cualquiera puede comprometerse: defensa en profundidad, mínimo privilegio, separación de responsabilidades y trazabilidad. El threat model de seguridad (distinto del threat model de proctoring) identifica cuatro actores: el **estudiante adversario** (quiere bypassar o manipular evidencia), el **atacante externo** (quiere datos por su valor), el **insider malicioso** (un empleado que quiere alterar evidencia o procesos), y el **error humano** (un comando equivocado, un deploy con bug).

### 12.2 Zero trust, JWT, OAuth2 y OpenID Connect

La identidad se delega a Keycloak (OAuth2/OIDC/SAML), federado con el directorio institucional mediante *just-in-time provisioning*. Los tokens JWT se validan localmente contra la clave pública de Keycloak (vía JWKS cacheado), lo que permite escalar sin consultar a Keycloak en cada request. Los access tokens duran 15–60 minutos; los refresh tokens rotan en cada uso. El MFA es **obligatorio** para roles con acceso a evidencia o administración (proctor, revisor, coordinador, administradores), con TOTP mínimo y WebAuthn recomendado.

### 12.3 Modelo de roles y permisos contextuales

Los roles reflejan el ciclo de vida del examen y la disciplina: estudiante, proctor, revisor académico, coordinador disciplinario, administrador de exámenes, administrador del sistema y auditor (solo lectura, incluido el audit log). Los permisos no son globales sino **contextuales**: un proctor observa exámenes específicos, un revisor tiene jurisdicción sobre su área. La descarga de un clip requiere una URL firmada que expira en 15 minutos, y ciertos accesos exigen *propósito declarado* que se persiste en el audit log.

### 12.4 Cadena de custodia: la evidencia defendible

Esta es la diferencia entre "recolectar evidencia" y "producir evidencia defendible". Cada pieza atraviesa cuatro etapas criptográficas acumulativas (las firmas no se reemplazan, se encadenan):

- 1) **CLIENTE** (al capturar)    SHA-256 del clip + firma HMAC con clave de sesión rotativa
- ▼
- 2) **BACKEND** (al recibir)    valida firma del cliente → recalcula hash → persiste metadata → deposita en bucket
- ▼
- 3) **WORKER** (asíncrono)    re-descarga → 3ª verificación de hash → firma con CLAVE MAESTRA (RSA-2048 / Ed25519)
- ▼
- 4) **RE-INFERENCIA** (opcional)    output del modelo (labels, confidences) firmado por el backend sobre el clip e

Cuando un estudiante apela alegando "la evidencia fue manipulada", la respuesta es **matemática, no testimonial**: un perito externo puede validar la cadena independientemente.



## 12.5 Audit log inmutable y almacenamiento WORM

El audit log es una tabla PostgreSQL append-only: un trigger rechaza UPDATE/DELETE, cada entrada incluye el hash de la anterior (una "blockchain rudimentaria" validada a diario), y los backups son físicamente separados con destino write-only leído solo por un sistema de auditoría externo. El bucket de evidencia usa Object Lock en modo Compliance (WORM): los objetos no se pueden modificar ni borrar durante la retención, ni siquiera por el propietario. Cifrado at-rest con KMS, versionado y logging activados.

## 12.6 Gestión de secretos, hardening y vulnerabilidades

Los secretos viven en HashiCorp Vault (o el secret manager del cloud), nunca en código, variables hardcodeadas ni imágenes Docker; se inyectan en tmpfs efímero. Rotación regular (passwords trimestral, claves API anual). Toda comunicación —externa e *interna* entre componentes— está cifrada (TLS 1.3, Postgres/Redis/RabbitMQ/MinIO con TLS). Protección contra SQLi (SQLAlchemy parametrizado), XSS (escape de React + DOMPurify), CSRF (JWT + SameSite + tokens dedicados), y fuerza bruta (rate limiting en Keycloak y Nginx). Gestión de vulnerabilidades: Dependabot, escaneo de imágenes con Trivy/Grype (no se despliega con críticas sin resolver), penetration testing al menos anual, y un canal de responsable disclosure.

## 13. Modelo de amenazas

La sección más importante para calibrar expectativas: qué SÍ puede detectar el sistema, qué NO, y por qué. El threat model se firma como contrato antes de desarrollar.

### 13.1 Por qué el threat model va antes que el diseño

Cada decisión de arquitectura depende del modelo de amenaza. La causa más común de fracaso en proctoring **no es técnica sino de expectativa**: la institución asume que el sistema previene fraude, lo usa para evaluaciones de alto impacto, y al primer bypass exitoso pierde la confianza —generando un costo reputacional y legal mayor que el del fraude que pretendía evitar.

### 13.2 Taxonomía de niveles de proctoring

#### NIVELES DE GARANTÍA DE PROCTORING — Y POR QUÉ SE DESCARTÓ CADA UNO

| NIVEL                       | DESCRIPCIÓN                                                                                                                                                                                        | POR QUÉ NO SE ELIGIÓ (O SÍ, EN L2.5)                                                                                                                          |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| L0 — Honor                  | Sin supervisión técnica. No es proctoring propiamente dicho.                                                                                                                                       | No ofrece ninguna garantía: el fraude no tiene costo. Descartado para evaluaciones sumativas.                                                                 |
| L1 — Disuasión liviana      | Hay cámara y aviso, pero ningún análisis real. Efecto psicológico, no probatorio.                                                                                                                  | No produce evidencia; no sostiene un proceso disciplinario. Insuficiente.                                                                                     |
| L2 — Análisis en cliente    | Detección automática y registro de eventos para revisión asíncrona. Sin identidad fuerte ni anti-tampering.                                                                                        | Buena base, pero sin biometría toda la evidencia opera sobre un supuesto no validado de identidad.                                                            |
| <b>L2.5 — ESTE SISTEMA</b>  | <b>Núcleo de L2 + verificación biométrica al inicio + anti-tampering pasivo.</b> Eleva el bypass de "trivial" a "técnico medio-alto", sin pretender ser inviolable. Ninguna sanción es automática. | <b>ELEGIDO:</b> el costo incremental sobre L2 es modesto y cierra el hueco de identidad. Garantía suficiente para el caso académico interno, sin sobrecostos. |
| L3 — Grabación completa     | Video/audio completo y durable, revisión de muestreos. Costo de storage y operación mucho mayor.                                                                                                   | Multiplica el costo de almacenamiento y operación, y compromete más la privacidad. Desproporcionado para impacto medio.                                       |
| L4 — Supervisión sincrónica | Proctor humano observando en vivo grupos pequeños (1:6–1:12).                                                                                                                                      | Inviabile a 700 concurrentes: exigiría 60–120 proctors por ventana. Costo prohibitivo.                                                                        |
| L5 — Lockdown nativo        | App dedicada que controla el SO + IA continua cliente y servidor + invalidación en tiempo real.                                                                                                    | Sería un proyecto distinto: desarrollo nativo por sistema operativo, instalación obligatoria, mantenimiento anti-cheat continuo. Excede el alcance.           |

En síntesis: bajar de L2.5 deja la evidencia sin sustento de identidad; subir a L3 multiplica costo y reduce privacidad; L4 no escala y L5 es otro proyecto. **L2.5 es el punto donde la curva costo-garantía es óptima para evaluaciones universitarias regulares.**

### 13.3 Matriz de modalidades de proctoring

Más allá de los siete niveles de garantía, en la práctica las modalidades de proctoring se agrupan en tres familias operativas según *cómo* interviene el factor humano: supervisión en vivo, automatización pura, e híbrido. El modelo adoptado pertenece a la familia **híbrida** (automatización + revisión humana asíncrona), que es el estándar recomendado para evaluaciones universitarias regulares. La matriz compara las tres familias en las dimensiones que importan para la decisión institucional.

COMPARATIVA DE MODALIDADES DE PROCTORING — CON EL PORQUÉ DE CADA DIMENSIÓN

| Dimensión               | En Vivo (Live)                                                                                  | Automatizado                                                                                    | Híbrido<br>★ ADOPTADO                                                                         | Por qué el híbrido es la mejor opción aquí                                                                                                                                                   |
|-------------------------|-------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Costo a escala          |  Alto          |  Bajo/fijo     |  Equilibrado | El en vivo paga decenas de proctors por examen; el comercial cobra por estudiante y escala sin techo. El híbrido tiene costo marginal cercano a cero porque la IA absorbe el volumen.        |
| Precisión               |  Alta        |  Riesgo de FP |  Más alta  | La IA sola confunde iluminación o gestos normales con fraude; la revisión humana sobre lo flaggeado corrige esos errores, elevando la precisión efectiva por encima de la automatizada pura. |
| Intervención humana     |  Tiempo real |  Ninguna     |  Asíncrona | La intervención en vivo no escala y la nula deja todo a la máquina. La asíncrona concentra el criterio humano donde realmente hace falta, sin atar un proctor a cada estudiante.             |
| Estrés del alumno       |  Alto        |  Moderado    |  Moderado  | Ser observado en vivo genera la mayor ansiedad. El híbrido evita la mirada constante: el alumno rinde sin un humano vigilando en tiempo real cada gesto.                                     |
| Escalabilidad operativa |  Limitada    |  Máxima      |  Alta      | Supervisar 700 en vivo exige 60–120 personas (inviable). El híbrido escala como el automatizado porque el cómputo corre en cada navegador y solo se revisa el 5–15%.                         |

| Dimensión            | En Vivo (Live) | Automatizado | Híbrido<br>★ ADOPTADO | Por qué el híbrido es la mejor opción aquí                                                                                                                                                         |
|----------------------|----------------|--------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Defensibilidad legal | ● Testimonial  | ● Sin humano | ● Evidencia + humano  | El proctor en vivo aporta solo su palabra; la IA sola, evidencia sin criterio. El híbrido suma cadena de custodia criptográfica + juicio humano documentado: lo único que sostiene una apelación.  |
| Caso de uso ideal    | ● Alto riesgo  | ● Formativas | ● Univ. regular       | Cada modalidad calza con su contexto: el en vivo con certificaciones de alto impacto, el automatizado con formativas masivas, el híbrido con la evaluación universitaria regular de impacto medio. |

Lectura de indicadores: ● favorable / pleno · ● intermedio / parcial · ○ desfavorable / ausente · ● fortaleza distintiva del modelo híbrido.

#### SÍNTESIS: POR QUÉ GANA EL HÍBRIDO

El modelo en vivo da máxima precisión pero no escala económicamente; el automatizado puro escala pero traslada el riesgo de falsos positivos directamente al estudiante sin filtro humano. El **híbrido captura lo mejor de ambos**: la IA filtra y prioriza a escala (costo marginal cercano a cero), y la revisión humana asíncrona —sobre el 5–15% de sesiones flaggeadas— elimina falsos positivos y aporta el criterio que sostiene la decisión disciplinaria. Ese balance —que ninguna otra opción logra a la vez— es exactamente la arquitectura L2.5 de este proyecto.

### 13.4 Por qué la automatización pura no alcanza para decisiones disciplinarias

Conviene detenerse en el riesgo central del proctoring automatizado puro, porque es la trampa en la que caen muchos despliegues. Un sistema que sanciona —o incluso solo que "marca como fraude"— sobre la base exclusiva de señales de IA produce **falsos positivos a escala**: el estudiante con iluminación deficiente, el que mira hacia arriba para pensar, el que tiene un hermano que cruza la habitación, el que usa una extensión legítima del navegador. A 700 estudiantes, incluso una tasa de falsos positivos del 2% significa 14 acusaciones potencialmente injustas por examen. Sin un humano que pondere el contexto, esas acusaciones erosionan la legitimidad del sistema más rápido de lo que cualquier fraude detectado la construye. Por eso el modelo híbrido no es una concesión sino una **decisión de diseño deliberada**: la IA nunca acusa, solo prioriza para que un humano mire.

### 13.5 Tabla extensa de amenazas

#### MODELO DE AMENAZAS — IMPACTO, PROBABILIDAD, MITIGACIÓN Y LÍMITE

| AMENAZA                                         | IMPACTO | PROBAB. | MITIGACIÓN                                                                                                  | LÍMITE (QUÉ NO CUBRE)                                                          |
|-------------------------------------------------|---------|---------|-------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Suplantación de identidad (otro rinde)          | Alto    | Media   | Verificación biométrica 1:1 + liveness + verificación silenciosa continua.                                  | Bypass con video pregrabado de alta calidad superando liveness.                |
| Consulta de material (otra pestaña, libro)      | Medio   | Alta    | Detección de cambio de pestaña/foco; análisis de mirada y postura; detección de monitores múltiples.        | Memorizar y recitar; material fuera del campo de la cámara.                    |
| Asistencia humana en la sala                    | Medio   | Media   | Detección de múltiples rostros; orientación corporal y mirada fuera de cuadro; (audio en fase 2).           | Cómplice fuera de cuadro pasando información en voz baja.                      |
| Manipulación técnica del cliente                | Medio   | Baja    | Anti-tampering pasivo (CSP, SRI, fingerprint, heartbeats firmados, detección de cámara virtual y DevTools). | Adversario sofisticado: aceptado explícitamente como límite del paradigma web. |
| Medios externos no observables (2ª PC, celular) | Alto    | Media   | Heurística estadística post-examen (tiempos anómalos, patrones de respuesta).                               | No hay detección en tiempo real. Fuera del alcance directo.                    |
| Coerción / chantaje                             | Alto    | Baja    | —                                                                                                           | Completamente fuera del alcance de cualquier sistema de proctoring.            |

#### ✓ Lo que el sistema SÍ puede detectar

Ausencia o múltiples rostros; cambio de pestaña y pérdida de foco; monitores adicionales; mirada sostenida fuera de pantalla; posturas anómalas; cambio de identidad durante el examen; señales de manipulación del cliente (como evidencia forense, no como bloqueo).

#### X Lo que el sistema NO puede detectar

Una segunda computadora o un celular fuera de cuadro; un cómplice susurrando fuera de cámara; conocimiento memorizado; un adversario técnico sofisticado que reescribe el cliente; coerción externa.  
**Por qué:** el cliente corre en una máquina no controlada y la cámara solo ve su campo visual.

## 13.6 El Acuerdo de Nivel de Proctoring

### CONTRATO DE HONESTIDAD

La salida de este análisis es un documento contractual firmado **antes** del desarrollo, que deja constancia del nivel L2.5, de qué amenazas se mitigan y cuáles no, de qué casos de uso son apropiados, y del compromiso institucional de sostener la revisión humana. Incluye una cláusula de revisión obligatoria si la institución quiere subir el nivel de uso. Sin este documento firmado, el desarrollo no avanza más allá de la fase cero.

## 13.7 Anatomía de un evento de proctoring

El proctoring de este sistema se construye sobre una unidad fundamental: el **evento**. Entender su anatomía es entender cómo opera realmente la supervisión. Un evento no es "fraude detectado": es una observación estructurada con metadatos, severidad y firma, que alimenta un score y eventualmente una revisión humana.

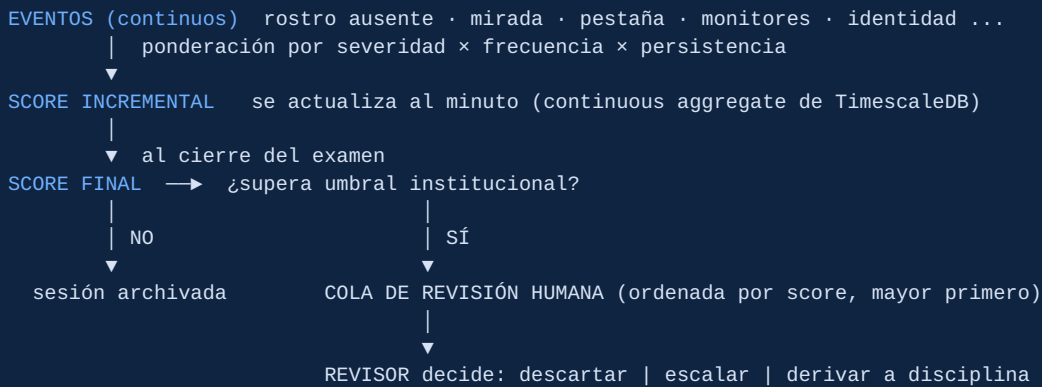
### TIPOS DE EVENTO, DISPARADOR Y SEVERIDAD TÍPICA

| TIPO DE EVENTO                      | DISPARADOR (REGLA DE TRANSICIÓN)                        | SEVERIDAD | TRATAMIENTO                                 |
|-------------------------------------|---------------------------------------------------------|-----------|---------------------------------------------|
| Rostro ausente                      | Sin rostro > 3 s sostenidos                             | Media     | Acumula; alerta moderada al panel.          |
| Múltiples rostros                   | ≥2 rostros durante N fotogramas consecutivos            | Alta      | Captura de evidencia automática.            |
| Mirada desviada sostenida           | Iris fuera del marco hacia un punto fijo                | Media     | Acumula al score; contexto para revisión.   |
| Cambio de pestaña / pérdida de foco | Evento de visibilidad del navegador                     | Media     | Registro; suma al score.                    |
| Monitor adicional detectado         | API de pantallas (donde el navegador lo permite)        | Alta      | Evidencia + alerta.                         |
| Posible cambio de identidad         | Embedding actual diverge del inicial                    | Crítica   | Atención inmediata del proctor.             |
| Tampering / cámara virtual          | Heurística de integridad (varianza de pixels, DevTools) | Alta      | Log forense, nunca abort automático.        |
| Corte de conectividad prolongado    | Reconexión tras > 5 min sin heartbeats                  | Crítica   | Evento crítico al reconectar.               |
| Heartbeat (no es anomalía)          | Cada 5 s, firmado con HMAC                              | Baseline  | Prueba de vida de la sesión y del detector. |

Cada evento incluye: identificador único, `session_id`, `exam_id`, tipo, severidad, timestamp del cliente, timestamp del backend al recibir, payload JSON específico, y firma. Esta estructura versionada es lo que permite reconstruir con exactitud qué ocurrió en una sesión meses después, durante una apelación.

## 13.8 Del evento al score de riesgo

El **score de riesgo** es el mecanismo que convierte cientos de eventos heterogéneos en una señal única y ordenable. No es un veredicto: es una prioridad para la cola de revisión. Se calcula incrementalmente durante el examen ponderando cada evento por su severidad, su frecuencia y su persistencia, de modo que un patrón sostenido pese más que un pico aislado, y eventos correlacionados (mirada desviada + pérdida de foco simultáneas) pesen más que la suma de sus partes.



#### EN PALABRAS SIMPLES

El score es como el nivel de prioridad de un correo: no dice "esto es spam con certeza", dice "mirá esto primero". Las sesiones con score más alto se revisan antes. Quien decide si realmente pasó algo es siempre el revisor humano.

### 13.9 El ciclo de revisión humana en detalle

La revisión humana es el corazón del modelo híbrido y el componente que la institución más subestima. Funciona así:

1. **Encolado:** al cerrar el examen, las sesiones que superan el umbral entran a la cola, ordenadas por score descendente.
2. **Asignación:** los revisores académicos toman sesiones de su jurisdicción. Cada apertura de sesión queda registrada en el audit log con propósito declarado.
3. **Contexto completo:** el revisor ve la línea de tiempo de eventos, los clips de evidencia firmados, las observaciones del proctor en vivo, el output de la re-inferencia server-side, y el audit log de accesos previos.
4. **Decisión:** emite una de tres resoluciones — **descartar** (falso positivo), **escalar** (requiere investigación adicional) o **derivar** a proceso disciplinario formal.
5. **Trazabilidad:** la decisión y su fundamento se persisten vinculados a la evidencia mediante referencias inmutables.

#### DIMENSIONAMIENTO DE LA REVISIÓN HUMANA (700 ESTUDIANTES)

| PARÁMETRO                           | VALOR ESTIMADO                                                                                         |
|-------------------------------------|--------------------------------------------------------------------------------------------------------|
| Sesiones flaggeadas por examen      | 5–15% → entre 35 y 105 sesiones                                                                        |
| Tiempo medio de revisión por sesión | 10–20 minutos                                                                                          |
| Carga total de revisión por examen  | ~6 a 35 horas-persona                                                                                  |
| Implicación operativa               | La institución debe asignar y capacitar revisores; sin este recurso, el sistema falla en su propósito. |

## 13.10 Falsos positivos vs. falsos negativos: la calibración del umbral

Todo sistema de detección enfrenta un tradeoff inevitable entre dos tipos de error, y la posición que se elige sobre ese tradeoff es una **decisión de política, no técnica**:

### Falso positivo

Marcar como sospechosa una sesión honesta. Costo: ansiedad y posible acusación injusta a un inocente; erosión de confianza si es frecuente. El sistema lo combate con umbrales conservadores y, sobre todo, con la revisión humana que filtra antes de cualquier sanción.

### Falso negativo

No detectar un fraude real. Costo: erosión de la integridad académica. El sistema lo reduce con múltiples detectores correlacionados y análisis estadístico post-examen, pero acepta que **no puede llevarlo a cero** sin disparar los falsos positivos.

La calibración se ajusta con **datos reales** en la fase 2: los umbrales del MVP son conservadores por defecto y se afinan observando la tasa real de cada tipo de error. La filosofía del sistema prioriza minimizar falsos positivos en la detección automática, porque el filtro humano posterior es quien recupera los verdaderos positivos sin castigar inocentes.

## 13.11 Consideraciones éticas y de experiencia del estudiante

El proctoring opera sobre una tensión legítima entre la integridad académica y los derechos y el bienestar del estudiante. Ignorar esta tensión es una causa frecuente de rechazo institucional. El sistema la aborda con decisiones concretas:

- **Minimización:** no se transmite video continuo; solo clips puntuales ante eventos. Los pixels viven en el dispositivo del estudiante.
- **Transparencia:** consentimiento informado en lenguaje claro antes de cada examen, explicando qué se monitorea y qué no.
- **Proporcionalidad:** el nivel L2.5 es deliberadamente moderado; no hay lockdown del sistema operativo ni grabación total.
- **No punición automática:** ninguna decisión disciplinaria se toma sin revisión humana, lo que protege al estudiante de errores algorítmicos.
- **Reducción de ansiedad:** bundle liviano para inicio rápido, mensajes claros ante fallos, escalación a proctor en lugar de abortar el examen.

### EL RIESGO DE ADOPCIÓN

La resistencia estudiantil —y la percepción de "vigilancia excesiva"— es un riesgo real que puede hundir un despliegue técnicamente impecable. La recomendación es comunicar a la comunidad con anticipación y transparencia, involucrar a representaciones estudiantiles en la definición de políticas, y publicar claramente el alcance del Acuerdo de Nivel de Proctoring para que nadie asuma capacidades de vigilancia que el sistema deliberadamente no tiene.



PARTE III

# Operación, escala e infraestructura

---

Observabilidad y operaciones, escalabilidad, infraestructura y DevOps.

## 14. Observabilidad y operaciones

*Los instrumentos que permiten operar el sistema bajo presión durante una ventana crítica.*

### 14.1 Los tres pilares

Métricas (Prometheus) para tendencias y agregaciones, logs estructurados (Loki) para detalle textual, y trazas distribuidas (OpenTelemetry → Tempo/Jaeger) para flujos que cruzan componentes. Grafana es la interfaz unificada. La complementariedad entre los tres pilares es lo que permite resolver incidentes complejos.

### 14.2 Métricas, logs y trazas

Las métricas se agrupan en cuatro niveles: **negocio** (sesiones activas, distribución de score, profundidad de la cola de revisión), **aplicación técnica** (latencias por percentil, profundidad de colas RabbitMQ, hit rate de Redis), **infraestructura** (CPU, memoria, disco, red) y **cliente agregado** (feeds degradados, dispositivos bajo perfil mínimo, versiones del cliente). Retención de 30 días en alta resolución y un año en baja (vía Thanos). Los logs son JSON con `trace_id` de correlación; el sampling de trazas preserva el 100% de errores y latencias altas más el 1% del tráfico normal.

### 14.3 Alertas, on-call y dashboards

Alertmanager categoriza alertas por severidad. Las **críticas** (que despiertan al on-call) indican impacto inmediato: instancias FastAPI caídas durante examen activo, base primaria inalcanzable, queue crítica creciendo, tasa de errores HTTP excedida. Cada alerta tiene un *runbook* asociado. Dashboards predefinidos: ejecutivo (estado simplificado para no técnicos), operacional (cara del on-call), exámenes en curso, capacidad y seguridad.

### 14.4 SLIs, SLOs y gestión de incidentes

#### INDICADORES Y OBJETIVOS DE NIVEL DE SERVICIO

| INDICADOR (SLI)                            | OBJETIVO (SLO)                     |
|--------------------------------------------|------------------------------------|
| Disponibilidad en ventana de examen activo | 99,9% (~9 s de inactividad en 3 h) |
| Disponibilidad fuera de ventana activa     | 99,5%                              |
| Latencia de detección en cliente (p99)     | sub-segundo                        |
| Latencia de propagación al panel (p99)     | < 500 ms                           |
| Latencia de re-inferencia y firma final    | < 30 s desde la subida             |
| Pérdida de eventos confirmados / evidencia | cero                               |

La gestión de incidentes sigue un ciclo: detección → declaración → mitigación → resolución → postmortem. Durante la mitigación el foco es **restaurar primero, diagnosticar después**. Cada incidente de severidad 1 o 2 genera una postmortem *blameless* en dos semanas, cuyas acciones entran al backlog con dueño y se trackean.

# 15. Escalabilidad

Cómo el sistema sostiene 700 concurrentes (y hasta ~2.100 en picos multi-examen), dónde están los cuellos de botella y cómo se escala.

## 15.1 El capacity model



Para 700 concurrentes: los heartbeats (cada 5 s) generan ~140 inserts/s y los eventos normales ~700 inserts/s, con picos de hasta 5.000. Un examen de una hora produce 4–5 millones de filas, que con la compresión de TimescaleDB se reducen a ~100–200 MB en disco. El tráfico de WebSockets es modesto (decenas a centenas de KB/s); las subidas de evidencia generan picos puntuales (~2,8 GB por examen a 4 clips/estudiante).

## 15.2 Cuellos de botella y cómo se abordan

### BOTTLENECKS IDENTIFICADOS

| CUELLO DE BOTELLA                              | ABORDAJE                                                                                           |
|------------------------------------------------|----------------------------------------------------------------------------------------------------|
| Inferencia de video                            | Resuelto por diseño: corre en el cliente, no en el servidor.                                       |
| Inserts en la base de eventos                  | Hypertable de TimescaleDB con chunks y compresión; agregados continuos para consultas.             |
| Pico de autenticación al inicio (~47 auth/min) | Cómodamente dentro de la capacidad de Keycloak en hardware modesto; la biometría corre en cliente. |
| Conexiones WebSocket por instancia             | Sticky sessions con 200–250 WS por instancia; monitoreo de distribución.                           |
| Subidas de evidencia pesadas                   | URLs firmadas: el cliente sube directo al storage, sin pasar por el backend.                       |

## 15.3 Escalado horizontal y dimensionamiento recomendado

La mayoría de los componentes escalan linealmente. Dimensionamiento para una institución a escala objetivo: 3 instancias FastAPI (4 vCPU / 8 GB), 2 workers críticos + 2 livianos, PostgreSQL primario robusto (8 vCPU / 32 GB / SSD con IOPS provisionados) más réplica streaming, Redis liviano (4 vCPU / 8 GB), RabbitMQ en 3 nodos (2 vCPU / 4 GB c/u), Keycloak en 2 instancias, y un servidor dedicado de observabilidad.

## 15.4 Migración a Kubernetes (escala mayor)

Cuando el sistema escale más allá de una institución o requiera autoescalado dinámico, la migración a Kubernetes es una evolución **operacional, no un rediseño**, porque cada componente ya es twelve-factor (probes, config por entorno, logs a stdout, sin estado local). Primero migran los componentes stateless (FastAPI, Celery, Nginx) y luego los stateful mediante operators (Patroni, RabbitMQ Cluster Operator, Redis Operator, MinIO Operator).

## 16. Infraestructura y DevOps

*Pragmatismo escalable: arrancar rápido con Docker Compose, preparado para Kubernetes desde el primer día.*

### 16.1 Topología inicial con Docker Compose

El despliegue inicial corre sobre 3–5 servidores: un nodo de proxy/frontend (Nginx), 2–3 de aplicación (FastAPI), uno de workers (Celery), un nodo de datos pesado (PostgreSQL primario + réplica + Redis + MinIO), y un nodo para RabbitMQ (3 nodos lógicos), Keycloak y observabilidad. Restricciones: la base primaria y su réplica en hosts distintos, RabbitMQ en al menos dos hosts, los workers intensivos sin competir con la base por CPU.

### 16.2 Entornos y CI/CD

La paridad entre staging y producción es prioritaria (misma estructura, datos sintéticos en staging). La pipeline (GitLab CI o GitHub Actions) tiene etapas de build (imágenes con tag inmutable por hash de commit), test, security scan (estático + imágenes + licencias), deploy automático a staging con smoke tests, y deploy **manual** a producción con aprobación de dos personas y **solo fuera de ventanas de examen activo**. Las versiones son inmutables; el rollback es un redeploy de la imagen anterior.

### 16.3 Backups, recuperación y DR

#### ESTRATEGIA DE RESPALDO Y RECUPERACIÓN

| COMPONENTE        | ESTRATEGIA                                                                                                              |
|-------------------|-------------------------------------------------------------------------------------------------------------------------|
| PostgreSQL        | Backup full diario + WAL streaming continuo → recuperación point-in-time. Retención 30 días / 1 año / 7 años (archivo). |
| MinIO (evidencia) | Replicación geográfica asíncrona cuando la infraestructura lo permite.                                                  |
| Redis             | No se respalda activamente (efímero); persistencia AOF para recuperar tras restart.                                     |
| RabbitMQ          | Quorum queues para durabilidad; definiciones como código en el repositorio.                                             |

#### OBJETIVOS DE RECUPERACIÓN

**RTO:** 4 horas para escenarios catastróficos (pérdida total del datacenter), 30 minutos para fallos menores. **RPO:** 5 minutos, gracias al WAL streaming continuo y la replicación geográfica. El plan de DR se prueba periódicamente con ejercicios de tabletop.

#### PARTE IV

# Planificación, riesgos y costos

---

Roadmap por fases, registro de riesgos, costos y tradeoffs, conclusión estratégica y recomendaciones futuras.

## 17. Roadmap del proyecto

Cuatro fases sucesivas con criterios de salida explícitos: no se avanza sin cumplirlos. Duración total estimada hasta operación sostenida: 12–18 meses.

### PLAN DE FASES — OBJETIVOS, ENTREGABLES, DURACIÓN Y CRITERIOS DE SALIDA

| FASE                                       | DURACIÓN                       | OBJETIVOS Y ENTREGABLES                                                                                                                                                                                                                                                                                                                                 | CRITERIOS DE SALIDA                                                                                                                                                  |
|--------------------------------------------|--------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Fase 0</b><br><b>Fundaciones</b>        | 4–8 semanas                    | No produce software, sino fundaciones contractuales y técnicas: firma del Acuerdo de Nivel de Proctoring, DPIA por el área legal, aprobación de los 14 ADRs (Tier 1), setup de infraestructura de desarrollo (repo, CI/CD, registry), conformación y onboarding del equipo, contratos y SLAs.                                                           | Documentos firmados, ADRs aprobados, infraestructura de dev funcional, equipo onboarded, primer sprint planeado.                                                     |
| <b>Fase 1</b><br><b>MVP</b>                | 3–5 meses                      | Ciclo completo de un examen: auth federada, <b>verificación biométrica con liveness desde el inicio</b> (no diferida), pipeline MediaPipe con eventos básicos, WebSockets + TimescaleDB + heartbeats firmados, cadena de custodia completa, panel de proctor mínimo, flujo de revisión humana, observabilidad básica, seguridad y privacidad, runbooks. | Funcionalidades testeadas, métricas de calidad cumplidas, documentación operacional, equipo on-call capacitado, piloto controlado exitoso con examen real.           |
| <b>Fase 2</b><br><b>Refinamiento</b>       | 2–4 meses                      | Corrección de hallazgos del piloto, features diferidas (análisis de audio, detección avanzada de tampering, integración LMS específica, paneles sofisticados), <b>calibración de modelos con datos reales</b> , endurecimiento operacional.                                                                                                             | Estabilidad sostenida (incidentes graves bajo umbral por trimestre), métricas en línea con proyecciones, satisfacción del cliente medida, documentación actualizada. |
| <b>Fase 3</b><br><b>Escala y evolución</b> | Indefinida (operación regular) | Migración a Kubernetes, preparación multi-tenancy si se ofrece a varias instituciones, capacidades avanzadas, integraciones adicionales, expansión geográfica.                                                                                                                                                                                          | Operacionales: SLA cumplido, costos por institución en línea, capacidad de incorporar nuevas instituciones en plazos razonables.                                     |

### 17.1 Riesgos del plan y contingencias

- **Demora de procesos institucionales** (firma, DPIA) → comenzar en paralelo trabajos técnicos que no dependen de los documentos.
- **Rotación del equipo** → documentación rica y pair programming en partes críticas.
- **Capacity model incorrecto** → monitoreo activo desde el día uno y capacidad de escalar rápido.
- **Cambio de nivel de proctoring durante el desarrollo** → proceso documentado de revisión del threat model que dispara renegociación contractual.

## 18. Riesgos del proyecto

Registro consolidado de riesgos en cuatro categorías. Los riesgos de threat model son inherentes al paradigma y se aceptan; los demás se mitigan.

REGISTRO DE RIESGOS (SELECCIÓN REPRESENTATIVA DEL REGISTRO COMPLETO R-001...R-030 / O / L)

| ID    | RIESGO                                                          | PROB.      | IMPACTO | MITIGACIÓN                                                                                         | ESTADO             |
|-------|-----------------------------------------------------------------|------------|---------|----------------------------------------------------------------------------------------------------|--------------------|
| R-001 | Bypass de detección por estudiante técnico medio                | Media-alta | Medio   | Anti-tampering pasivo, análisis estadístico de sesiones "demasiado limpias", cláusula contractual. | Aceptado           |
| R-002 | En disputa se argumenta evidencia razonable, no prueba absoluta | Alta       | Medio   | Cadena de custodia formal, capacitación de revisores.                                              | Aceptado           |
| R-003 | Falsos positivos por hardware de baja calidad                   | Media      | Alto*   | Detección de capacidad mínima, umbrales conservadores, escalación a proctor.                       | Mitigado           |
| R-006 | Hardware insuficiente para Face Mesh + Pose simultáneos         | Media      | Medio   | Detección de capacidad, degradación graceful, fallback a Face Detection.                           | Mitigado           |
| R-010 | Liveness bypassable con video pregrabado de calidad             | Baja       | Medio   | Verificación continua + revisión humana.                                                           | Aceptado           |
| R-026 | Compromiso de la clave maestra de firma                         | Baja       | Crítico | Rotación anual, archivo seguro de claves previas, plan de respuesta documentado.                   | Mitigado           |
| O-001 | On-call insuficientemente capacitado en incidente crítico       | Media      | Alto    | Capacitación obligatoria, simulacros, runbooks, doble cobertura en picos.                          | En mitigación      |
| O-003 | Capacidad insuficiente de revisión humana en la institución     | Media      | Alto    | Estimación temprana de carga, capacitación, monitoreo de backlog.                                  | Acción del cliente |
| L-001 | Cambio regulatorio en protección de datos                       | Baja       | Alto    | Monitoreo del marco, revisión legal anual, adaptabilidad de retención.                             | Aceptado/monitoreo |
| L-002 | Caso disciplinario que llega a la justicia ordinaria            | Baja       | Alto    | Cadena de custodia robusta, capacidad de peritaje, asesoría legal.                                 | Mitigado           |



| ID    | RIESGO                                                     | PROB. | IMPACTO | MITIGACIÓN                                                                    | ESTADO   |
|-------|------------------------------------------------------------|-------|---------|-------------------------------------------------------------------------------|----------|
| L-004 | Brecha entre expectativas del cliente y capacidades reales | Media | Alto    | Acuerdo de Nivel de Proctoring, comunicación regular, ajuste de expectativas. | Mitigado |

\* Alto sobre el estudiante individual afectado, bajo en agregado.

## 18.1 Dimensiones de riesgo

### Técnicos

Manipulación del cliente, hardware insuficiente, dependencia de versiones de MediaPipe, complejidad del stack de mensajería, WebSocket fan-out.

### Operativos

On-call no capacitado, pérdida de personal clave, **capacidad de revisión humana** (el más subestimado), desactualización de dependencias, drift de configuración.

### Legales y éticos

Tratamiento de datos biométricos, derecho al olvido vs. retención forense, transferencias internacionales, transparencia con el estudiante.

### Académicos y de adopción

Resistencia estudiantil, percepción de vigilancia excesiva, falsos positivos que afectan a inocentes, sostenibilidad del compromiso institucional.

## 19. Costos y tradeoffs

El análisis económico que sustenta la decisión de construir en lugar de comprar, con sus tradeoffs honestos.

### 19.1 Estructura de costos de la plataforma propia

#### CATEGORÍAS DE COSTO

| CATEGORÍA                 | CARACTERÍSTICAS                                                                                                                                             |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Infraestructura           | 3–5 servidores modestos para la escala objetivo. Costo fijo y predecible, independiente del volumen de exámenes (a diferencia del pricing comercial).       |
| Procesamiento distribuido | Cercano a cero en costo marginal: la inferencia corre en los dispositivos de los estudiantes, no en infraestructura institucional.                          |
| Almacenamiento            | ~1,4 TB en estado estacionario con retención de 2 años (~700 GB/año a 5 exámenes/semana). Archivo a Parquet/cold storage reduce el costo de datos antiguos. |
| Observabilidad            | Un servidor dedicado; retención escalonada (30 días alta resolución, 1 año baja).                                                                           |
| Mantenimiento y operación | Equipo competente de tamaño moderado, on-call, ventanas de mantenimiento. <b>No es trivial</b> y es el costo recurrente principal.                          |
| Revisión humana           | Personal institucional (no del proveedor): 30–100 sesiones/examen a 10–20 min c/u. Costo institucional ineludible.                                          |

### 19.2 Ahorro respecto de plataformas comerciales

El modelo comercial cobra por estudiante por examen, escalando linealmente con la matrícula. La plataforma propia convierte ese gasto recurrente y creciente en una **inversión amortizable** con costo marginal cercano a cero por estudiante adicional. A horizonte de cinco años, y especialmente al incluir los costos no financieros de soberanía, adaptabilidad y reducción de dependencia, el análisis favorece construir.

### 19.3 Tradeoffs honestos

#### CONSTRUIR VS. COMPRAR — TRADEOFFS

| DIMENSIÓN          | PLATAFORMA PROPIA (ESTA PROPUESTA)   | PLATAFORMA COMERCIAL                 |
|--------------------|--------------------------------------|--------------------------------------|
| Costo inicial      | Mayor (desarrollo)                   | Bajo (suscripción)                   |
| Costo a 5 años     | Menor y predecible                   | Mayor y creciente con el volumen     |
| Soberanía de datos | Completa                             | Limitada (datos en terceros)         |
| Adaptabilidad      | Total                                | Restringida al mercado del proveedor |
| Carga operacional  | Propia (equipo competente requerido) | Delegada al proveedor                |
| Time-to-market     | 12–18 meses                          | Inmediato                            |

#### EL TRADEOFF CENTRAL

La plataforma propia cambia **gasto recurrente y dependencia** por **inversión inicial y responsabilidad operacional**. Es la decisión correcta cuando la institución valora la soberanía y opera a un volumen donde el pricing comercial se vuelve oneroso —no lo es para quien necesita una solución inmediata y de bajo volumen.

## 20. Conclusión estratégica y recomendaciones futuras

*Evaluación general, FODA, viabilidad y la evolución hacia la madurez arquitectónica y el modelo SaaS multi-institucional.*

### 20.1 Evaluación general

El proyecto presenta una arquitectura **coherente, honesta y bien fundamentada**. Su mayor fortaleza no es técnica sino conceptual: la disciplina de declarar explícitamente lo que el sistema hace y lo que no, formalizada en un Acuerdo de Nivel de Proctoring firmado antes del desarrollo. Esta honestidad arquitectónica es lo que permite construir políticas disciplinarias defendibles, y es precisamente lo que falta en los proyectos de proctoring que fracasan. La decisión central —desplazar la IA al navegador y tratar al cliente como sensor no confiable verificado por el backend— resuelve simultáneamente el problema de escala, de costo y de privacidad.

### 20.2 Análisis FODA

#### Fortalezas

Honestidad arquitectónica y threat model contractual; escala viable a bajo costo marginal; soberanía de datos completa; cadena de custodia criptográfica defendible; observabilidad de primera clase; preparación para Kubernetes sin rediseño; privacidad por diseño.

#### Debilidades

Carga operacional propia no trivial; dependencia crítica de la capacidad de revisión humana institucional; límites reales de detección (medios externos, adversario sofisticado); time-to-market de 12–18 meses frente a la inmediatez comercial.

#### Oportunidades

Activo institucional reutilizable; conocimiento interno en IA y sistemas distribuidos; expansión multi-tenant a otras instituciones; posicionamiento como referente regional; base para futuros productos académicos.

#### Amenazas

Cambios regulatorios en datos biométricos; resistencia estudiantil; un caso que escale a la justicia ordinaria; expansión silenciosa del scope fuera del nivel acordado; rotación del equipo en un proyecto de varios años.

### 20.3 Viabilidad

La viabilidad **técnica** es alta: el stack es maduro, las decisiones están justificadas y el capacity model es realista. La viabilidad **económica** es favorable a horizonte de cinco años para una institución del volumen descrito. La viabilidad **operacional** es condicional: depende de que la institución sostenga el equipo técnico y, sobre todo, la capacidad de revisión humana. La viabilidad **legal** requiere completar el DPIA y firmar los

acuerdos antes de desarrollar. El factor de riesgo dominante no es tecnológico sino organizacional: el compromiso institucional sostenido.

## 20.4 Recomendaciones

- **No saltar la Fase 0.** Firmar el Acuerdo de Nivel de Proctoring y completar el DPIA antes de escribir código; es la mejor protección contra el fracaso por expectativas mal calibradas.
- **Designar y capacitar a la coordinación operativa y a los revisores** antes de la Fase 1. Es la dependencia más subestimada.
- **Validar el capacity model contra datos reales** al cierre del piloto y trimestralmente el primer año.
- **Comunicar a la comunidad estudiantil con transparencia** qué se monitorea y qué no, para mitigar la resistencia y la percepción de vigilancia.
- **Mantener el threat model como contrato vivo:** cualquier intento de usar el sistema para evaluaciones de mayor impacto debe disparar su revisión formal.

## 20.5 Evolución futura y madurez arquitectónica

### HORIZONTE DE EVOLUCIÓN

| EJE                           | EVOLUCIÓN PROPUESTA                                                                                                                                                                      |
|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Capacidades de detección      | Análisis de audio para voces múltiples, detección avanzada de cámara virtual, verificación con documento, analítica estadística cruzada de patrones de respuesta.                        |
| Madurez operacional           | De Docker Compose a Kubernetes con autoescalado; refinamiento continuo de runbooks y SLOs basado en postmortems.                                                                         |
| Expansión multi-institucional | Activación del modelo multi-tenant para ofrecer la plataforma como servicio a universidades menores del ecosistema regional.                                                             |
| Evolución SaaS                | Onboarding estandarizado de instituciones, aislamiento de datos por tenant, facturación, y SLAs diferenciados —preservando los principios de soberanía y privacidad para cada tenant.    |
| Calibración por IA            | Uso de los datos de operación (anonimizados, con consentimiento) para optimizar umbrales y reducir falsos positivos, mejorando la calidad de detección sin elevar el nivel de intrusión. |

### CIERRE

El éxito del proyecto no se medirá solo en métricas técnicas, sino en una pregunta más exigente: al cabo de un año de operación productiva, ¿puede la institución sostener su programa de evaluaciones remotas con confianza, a volumen significativo, sin incidentes de privacidad y con casos disciplinarios que se sostienen cuando se apelan? Si la respuesta es afirmativa, la arquitectura aquí descrita habrá cumplido su propósito. Todas sus decisiones —desde la IA en el navegador hasta la cadena de custodia criptográfica— están subordinadas a ese objetivo final.

---

Este documento es un instrumento de planificación y validación de alcance. Mantiene expectativas realistas de forma deliberada: no promete detección perfecta ni prevención absoluta del fraude, sino detección con calidad razonable y evidencia defendible bajo revisión humana.

## PARTE V

# Apéndices técnicos

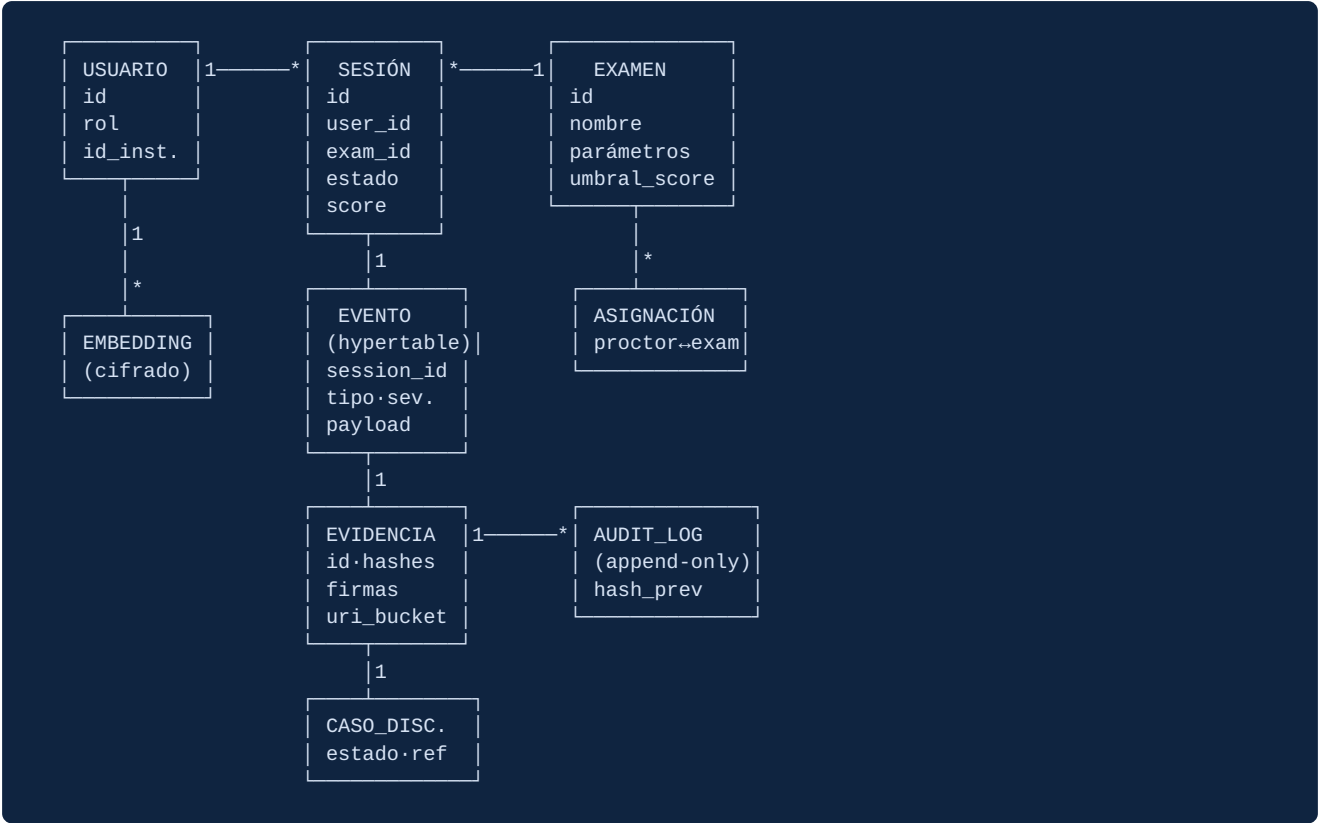
---

Modelo de datos, contratos de API, diagramas de secuencia, ADRs, plan de pruebas, runbooks, gestión del cambio y glosario.

# T1. Modelo de datos y entidades

Las entidades de dominio, sus relaciones y la separación entre datos transaccionales y series temporales.

## T1.1 Diagrama entidad-relación (conceptual)



## T1.2 Entidades transaccionales (PostgreSQL)

### ENTIDADES DE DOMINIO Y ATRIBUTOS CLAVE

| ENTIDAD   | ATRIBUTOS PRINCIPALES                                                                                                | NOTAS                                                  |
|-----------|----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------|
| Usuario   | id, identificador institucional, rol(es), email, atributos federados                                                 | Provisionado just-in-time desde el IdP.                |
| Examen    | id, nombre, parámetros de monitoreo, detectores activos, umbral de score, ventana temporal, política de retención    | Configurado por el administrador.                      |
| Sesión    | id, user_id, exam_id, estado (iniciada/activa/finalizada/flaggeada/cerrada), score, clave de sesión, timestamps      | Entidad central del ciclo de vida.                     |
| Embedding | id, user_id, vector cifrado, versión, fecha                                                                          | Dato biométrico; cifrado at-rest; eliminado al egreso. |
| Evidencia | id, session_id, uri_bucket, hash_cliente, firma_cliente, hash_backend, firma_maestra, output_reinferencia, metadatos | Cadena de custodia completa.                           |
| Audit log | id, actor, timestamp, IP, user-agent, acción, evidencia_id, propósito, hash_entrada_anterior                         | Append-only; cadena de hashes.                         |



| ENTIDAD                   | ATRIBUTOS PRINCIPALES                                                                  | NOTAS                                     |
|---------------------------|----------------------------------------------------------------------------------------|-------------------------------------------|
| <b>Caso disciplinario</b> | id, session_id, estado, referencias a evidencia, decisiones, vínculo a sistema externo | Extiende retención mientras esté abierto. |
| <b>Consentimiento</b>     | id, user_id, exam_id, versión_texto, timestamp, hash                                   | Registro inmutable de la sesión.          |

### T1.3 Datos de series temporales (TimescaleDB)

La tabla de **eventos** es una hypertable particionada por día. Esquema: id, session\_id, exam\_id (denormalizado), tipo, severidad, timestamp\_cliente, timestamp\_backend, payload (JSON), firma. Índices por (session\_id, timestamp) y (exam\_id, timestamp). Compresión automática 7 días–1 año; archivo a Parquet más allá de 1 año. Los *continuous aggregates* mantienen: eventos por sesión por minuto, score por sesión, sesiones activas por examen, distribución por tipo en la última hora.

## T2. Contratos de API y canales WebSocket

La superficie de integración del backend: endpoints REST versionados y canales WebSocket por rol.

### T2.1 Endpoints REST principales

#### API REST (V1) — SELECCIÓN REPRESENTATIVA

| MÉTODO | ROUTA                                | PROPÓSITO                                                                               |
|--------|--------------------------------------|-----------------------------------------------------------------------------------------|
| POST   | /api/v1/auth/refresh                 | Refresco de token (validación de JWT de Keycloak).                                      |
| POST   | /api/v1/exams                        | Crear examen (admin).                                                                   |
| POST   | /api/v1/exams/{id}/students          | Asignar estudiantes habilitados.                                                        |
| POST   | /api/v1/sessions                     | Iniciar sesión de examen.                                                               |
| GET    | /api/v1/sessions/{id}                | Obtener estado de la sesión.                                                            |
| POST   | /api/v1/sessions/{id}/verify         | Enviar artefactos de verificación biométrica.                                           |
| POST   | /api/v1/sessions/{id}/finish         | Finalizar sesión ordenadamente.                                                         |
| POST   | /api/v1/evidence/presign             | Obtener URL firmada para subir un clip.                                                 |
| GET    | /api/v1/exams/{id}/events            | Consultar eventos/agregaciones (panel).                                                 |
| GET    | /api/v1/review/queue                 | Cola de revisión ordenada por score.                                                    |
| POST   | /api/v1/review/{session_id}/decision | Emitir decisión terminal de revisión.                                                   |
| POST   | /api/v1/evidence/{id}/verify-chain   | Generar certificado de verificación de la cadena de custodia.                           |
| POST   | /api/v1/dsr/{type}                   | Solicitudes de derechos del titular (acceso, rectificación, eliminación, portabilidad). |

### T2.2 Canales WebSocket

#### CANALES EN TIEMPO REAL POR ROL

| CANAL                            | DIRECCIÓN Y USO                                                                                          |
|----------------------------------|----------------------------------------------------------------------------------------------------------|
| /ws/student/session/{session_id} | Cliente ↔ backend: eventos, heartbeats firmados, comandos del servidor (fin de tiempo, re-verificación). |
| /ws/proctor/exam/{exam_id}       | Backend → panel: flujo de eventos en vivo de las sesiones del examen asignado.                           |
| /ws/admin/system                 | Backend → herramientas administrativas: estado del sistema (autorización elevada).                       |

Autorización: JWT en el header en cada request HTTP; en WebSockets, validación en el handshake y revalidación periódica de la autorización contextual (p. ej., "este proctor está autorizado a observar este examen").

## T2.3 Esquema de eventos (versionado)

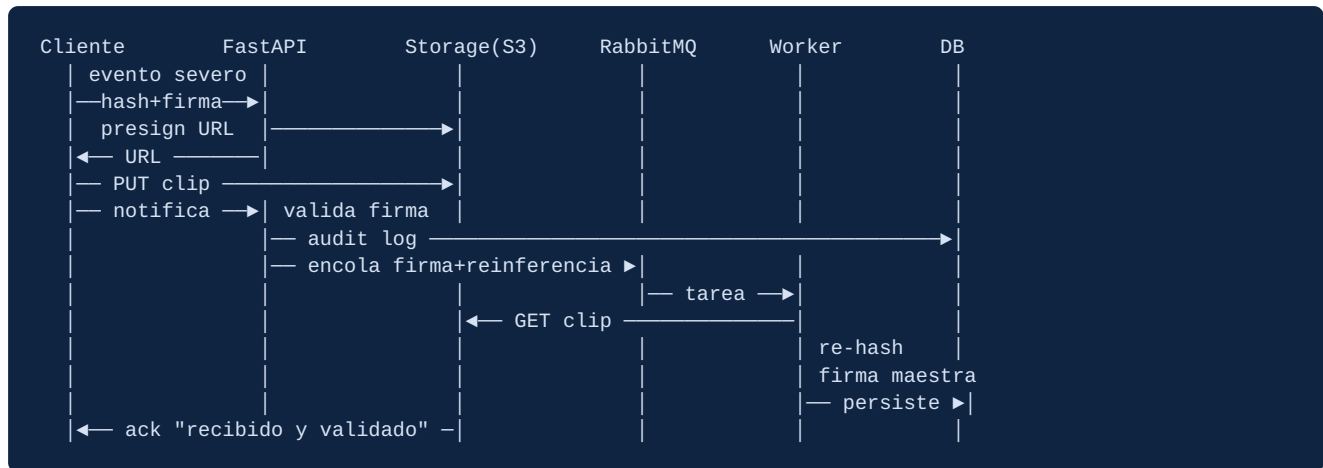
```
{
  "schema_version": "1.2",
  "event_id": "uuid",
  "session_id": "uuid",
  "exam_id": "uuid",
  "type": "multiple_faces | face_absent | gaze_off | tab_blur | ...",
  "severity": "baseline | low | medium | high | critical",
  "ts_client": "ISO-8601",
  "ts_backend": "ISO-8601 (completado al recibir)",
  "payload": { /* específico del tipo: bbox, confidence, duración... */ },
  "signature": "HMAC-SHA256 con clave de sesión"
}
```

El versionado del esquema (`schema_version`) permite evolucionar los eventos sin romper sesiones en curso ni la reconstrucción forense de exámenes pasados. Los cambios siguen reglas de compatibilidad hacia atrás.

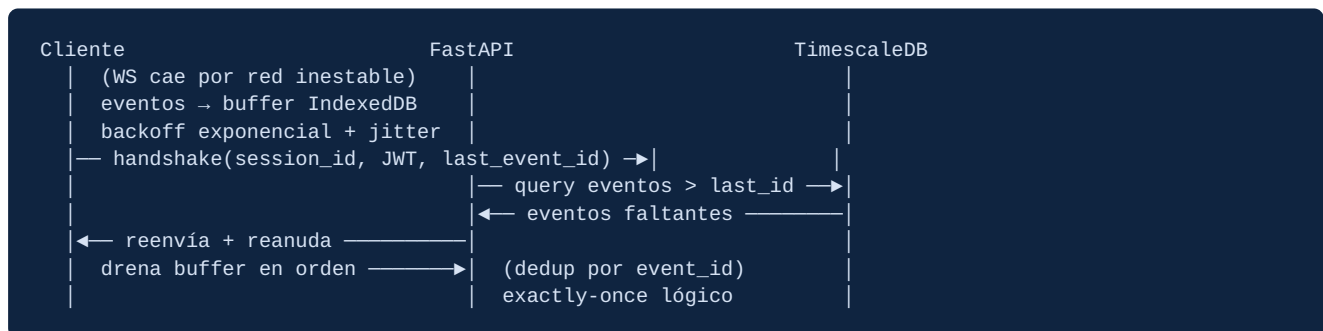
## T3. Diagramas de secuencia

Los flujos críticos descritos como interacciones temporales entre componentes.

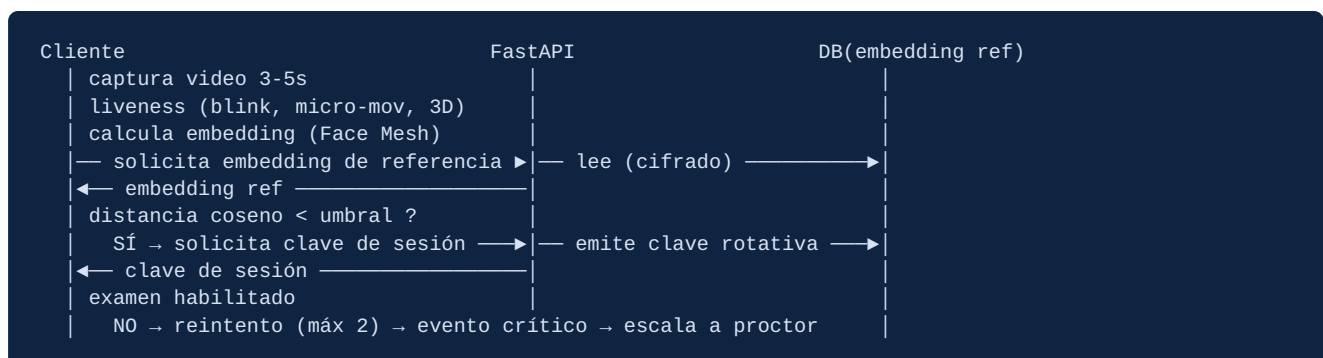
### T3.1 Captura y firma de evidencia



### T3.2 Reconexión sin pérdida de eventos



### T3.3 Verificación de identidad inicial



## T4. Architecture Decision Records (ADRs)

Las decisiones arquitectónicas significativas, cada una con su contexto, la decisión tomada, las alternativas y las consecuencias. Materializan la cultura de honestidad arquitectónica.

### REGISTRO DE ADRS (TIER 1 Y TIER 2)

| ADR  | DECISIÓN                              | CONTEXTO Y CONSECUENCIA                                                                                                         | ALTERNATIVA DESCARTADA                                              |
|------|---------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|
| 0001 | Nivel de proctoring L2.5              | Calibra expectativas y todas las decisiones posteriores. Acepta bypass por adversario sofisticado; ninguna sanción automática.  | L2 puro (insuficiente) / L3+ (desproporcionado en costo).           |
| 0002 | Procesamiento en cliente              | IA en el navegador para viabilizar la escala a costo sostenible. El backend trata al cliente como sensor no confiable.          | Inferencia centralizada (10–50× más cara).                          |
| 0003 | Verificación biométrica desde el MVP  | Sin identidad fuerte, toda la evidencia opera sobre un supuesto no validado. Se incluye en Fase 1.                              | Diferir biometría a fase posterior.                                 |
| 0004 | Anti-tampering pasivo                 | Eleva el costo del bypass sin pretender inviolabilidad; modo log, no abort, para evitar falsos positivos.                       | Lockdown nativo (otro proyecto, L5).                                |
| 0005 | TimescaleDB para eventos              | Hypertables, compresión y agregados continuos resuelven el patrón de escritura intensa. Es extensión de Postgres, no otra DB.   | PostgreSQL nativo (se degrada); NoSQL (rompe consistencia).         |
| 0006 | RabbitMQ para tareas críticas         | Durabilidad por consenso Raft (quorum queues) para re-inferencia y firma, cuya pérdida rompería la cadena de custodia.          | Redis como broker (durabilidad insuficiente).                       |
| 0007 | Cadena de custodia con Object Lock    | WORM + firmas encadenadas + audit log inmutable hacen la evidencia defendible matemáticamente.                                  | Almacenamiento plano sin inmutabilidad.                             |
| 0008 | Fan-out híbrido y sticky sessions     | Redis Pub/Sub para eventos no críticos, RabbitMQ durable para alertas críticas; sticky sessions evitan distribuir estado de WS. | Estado de WS distribuido (complejidad sin beneficio a esta escala). |
| 0009 | Keycloak como IdP                     | Federación, MFA y gestión de roles maduras; auth a medida es catastrófica si falla.                                             | Autenticación propia.                                               |
| 0010 | FastAPI mono-hilo escalado horizontal | Una instancia = un proceso = un pod; métricas interpretables y migración trivial a K8s.                                         | Multi-worker dentro de la instancia.                                |
| 0011 | Despliegue inicial con Docker Compose | Time-to-market del piloto; twelve-factor desde el día uno para migrar a K8s sin reescritura.                                    | Kubernetes desde el inicio (sobrecarga prematura).                  |
| 0012 | Observabilidad de primera clase       | Prometheus/Loki/Tempo/Grafana desde Fase 0; una función no observable no se considera lista.                                    | Observabilidad como fase posterior.                                 |
| 0013 | Privacidad por diseño                 | Minimización (sin video continuo), retención configurable, derechos del titular nativos.                                        | Recolección amplia "por si acaso".                                  |

| ADR  | DECISIÓN                                   | CONTEXTO Y CONSECUENCIA                                               | ALTERNATIVA<br>DESCARTADA                              |
|------|--------------------------------------------|-----------------------------------------------------------------------|--------------------------------------------------------|
| 0014 | Acuerdo de Nivel de Proctoring contractual | Firma antes de desarrollar; sin él, el proyecto no pasa de la Fase 0. | Threat model solo como sección técnica que pocos leen. |

## T5. Estrategia de calidad y plan de pruebas

Cómo se asegura que el sistema funciona y sigue funcionando, en un dominio donde un fallo durante un examen es una crisis institucional.

### T5.1 Pirámide de pruebas

#### NIVELES DE PRUEBA Y COBERTURA

| NIVEL              | QUÉ CUBRE                                                                                                                                                       | HERRAMIENTAS / ENFOQUE                                     |
|--------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| Unitarias          | Lógica de dominio pura (reglas de transición de eventos, cálculo de score, verificación de integridad). Robustez máxima: los bugs aquí son los más caros tarde. | pytest; aislamiento total del dominio.                     |
| Integración        | Interacción entre capas: repositorios ↔ Postgres, publisher ↔ Redis, productor ↔ RabbitMQ, cliente ↔ MinIO.                                                     | Contenedores efímeros de prueba.                           |
| Contrato           | Esquema de eventos versionado, contratos de API, compatibilidad hacia atrás de migrations.                                                                      | Validación de schema; tests de compatibilidad.             |
| End-to-end         | Flujos completos: verificación → examen → evidencia → revisión.                                                                                                 | Automatización de navegador.                               |
| Carga / estrés     | 700 concurrentes, pico de inicio simultáneo, tasa de inserts, latencias bajo carga.                                                                             | Generadores de carga; validación contra el capacity model. |
| Seguridad          | Análisis estático, escaneo de imágenes (Trivy/Grype), penetration testing.                                                                                      | SAST en CI; pentest ≥ anual.                               |
| Caos / resiliencia | Caída de instancia, corte de red del cliente, pérdida de nodo RabbitMQ.                                                                                         | Inyección de fallos; ejercicios de DR.                     |

### T5.2 Criterios de calidad por fase (Definition of Done)

- **Cobertura de tests** dentro del umbral acordado, con foco en el dominio.
- **Cero vulnerabilidades críticas** conocidas en dependencias e imágenes.
- **Performance dentro de objetivos** (NFR-03 a NFR-05) validada bajo carga.
- **Observabilidad completa**: métricas, logs y alertas para cada flujo crítico.
- **Documentación operacional**: runbooks de los escenarios principales.
- **Piloto controlado exitoso** con un examen real antes de declarar la fase cerrada.

## T6. Runbooks y operación

Procedimientos documentados para que el on-call responda con consistencia bajo presión. Restaurar primero, diagnosticar después.

### T6.1 Estructura de un runbook

Cada alerta tiene un runbook con: descripción de qué indica, pasos de verificación (¿es real o falso positivo?), mitigación inmediata, criterios de escalación, e investigación de causa raíz una vez mitigado. Viven en un wiki versionado y se actualizan tras cada incidente.

### T6.2 Runbooks principales

#### ESCENARIOS DE INCIDENTE Y MITIGACIÓN

| ESCENARIO (ALERTA)                           | SEVERIDAD | MITIGACIÓN INMEDIATA                                                                                 |
|----------------------------------------------|-----------|------------------------------------------------------------------------------------------------------|
| Instancia FastAPI no responde durante examen | Sev 1     | Health check la saca del pool; clientes reconectan a otra instancia; reiniciar/reemplazar instancia. |
| Base primaria con replicación detenida       | Sev 1     | Verificar lag; promover réplica si el primario no recupera; restaurar replicación.                   |
| Queue crítica de RabbitMQ creciendo          | Sev 1-2   | Escalar workers de re-inferencia/firma; revisar DLX; identificar input corrupto.                     |
| Redis con memoria crítica                    | Sev 2     | Verificar claves; ampliar memoria; revisar TTLs; el estado durable está en Postgres.                 |
| MinIO con error de escritura                 | Sev 1-2   | Verificar espacio y permisos; los clips quedan en buffer; reintentar subida.                         |
| Keycloak no autentica                        | Sev 1     | Failover a la 2.ª instancia; verificar federación con el IdP institucional.                          |
| Tasa elevada de tampering detectado          | Sev 2     | Verificar falsos positivos por extensiones; ponderación humana; no abortar exámenes.                 |
| Espacio en disco crítico                     | Sev 2     | Forzar archivado de chunks; limpiar logs antiguos; ampliar volumen.                                  |

### T6.3 Gestión de incidentes y postmortems

Ciclo: detección → declaración (con canal dedicado en Sev 1) → mitigación → resolución → postmortem. Las postmortems son **blameless**, se completan en dos semanas, y sus acciones entran al backlog con dueño y seguimiento. Matriz de escalación por severidad y tiempo, con cobertura 24x7 durante exámenes activos.



## T7. Gestión del cambio y adopción

*Un sistema técnicamente impecable fracasa si la organización no lo adopta. El plan de gestión del cambio es tan crítico como la arquitectura.*

### T7.1 Plan de capacitación

#### CAPACITACIÓN POR ROL

| ROL                       | CONTENIDO                                                                                                   |
|---------------------------|-------------------------------------------------------------------------------------------------------------|
| Coordinación operativa    | Asignación de proctors, gestión de la cola, escalación a TI, lectura de métricas operacionales.             |
| Proctors en vivo          | Uso del panel, interpretación de alertas, intervención, registro de observaciones, cierre forzado.          |
| Revisores académicos      | Lectura de evidencia y contexto, criterios de decisión, cómo argumentar evidencia razonable en apelaciones. |
| On-call / TI              | Runbooks, observabilidad, despliegues, backups y recuperación, simulacros de incidentes.                    |
| Administradores de examen | Configuración de exámenes, parámetros de monitoreo, asignación de estudiantes.                              |

### T7.2 Comunicación a la comunidad estudiantil

La adopción exige transparencia **proactiva**: comunicar antes del primer examen qué se monitorea y qué no, publicar los requisitos de dispositivo, explicar el flujo de consentimiento y los derechos del titular, e involucrar a representaciones estudiantiles en la definición de políticas. El objetivo es desactivar la percepción de "vigilancia excesiva" mostrando los límites deliberados del sistema (sin video continuo, sin lockdown, sin sanción automática).

### T7.3 Estrategia de despliegue gradual

- **Piloto controlado**: un examen real con un número limitado de estudiantes, monitoreo intensivo y feedback cualitativo.
- **Expansión escalonada**: incremento progresivo de exámenes y volumen, validando el capacity model en cada salto.
- **Operación sostenida**: incorporación al calendario académico regular con SLAs en vigor.
- **Revisión continua**: el documento de visión y el threat model se revisan al cierre de cada fase.

## T8. Glosario

*Términos técnicos clave, explicados para audiencias mixtas.*

### GLOSARIO DE TÉRMINOS

| TÉRMINO                    | DEFINICIÓN                                                                                                     |
|----------------------------|----------------------------------------------------------------------------------------------------------------|
| Proctoring                 | Supervisión de un examen para preservar su integridad.                                                         |
| L2.5                       | Nivel de proctoring adoptado: análisis en cliente + biometría + anti-tampering pasivo, sin sanción automática. |
| Embedding facial           | Vector numérico que resume rasgos de un rostro; una "huella matemática", no la foto.                           |
| Liveness                   | Verificación de que frente a la cámara hay una persona viva, no una foto o video.                              |
| Heartbeat                  | Señal firmada periódica (cada 5 s) que prueba que la sesión y el detector siguen activos.                      |
| Evento                     | Observación estructurada con severidad y firma; unidad básica del proctoring.                                  |
| Score de riesgo            | Valor que prioriza sesiones para revisión humana; no es un veredicto.                                          |
| Cadena de custodia         | Secuencia de hashes y firmas que hace la evidencia defendible y verificable por un perito.                     |
| Audit log                  | Registro append-only de cada acceso a evidencia; imposible de modificar sin dejar rastro.                      |
| WORM / Object Lock         | Almacenamiento que se escribe una vez y no se puede modificar ni borrar durante la retención.                  |
| Hypertable                 | Tabla de TimescaleDB particionada por tiempo, optimizada para escritura intensa y compresión.                  |
| Sticky session             | Asignación de un cliente a una misma instancia del backend mientras dure su conexión.                          |
| Fan-out                    | Propagación de un evento desde donde ocurre hacia todos los paneles que deben verlo.                           |
| Re-inferencia server-side  | Segundo análisis de la evidencia en el servidor para validar lo que reportó el cliente y detectar tampering.   |
| Quorum queue               | Cola de RabbitMQ con consenso entre nodos que garantiza durabilidad ante caídas.                               |
| DLX (Dead Letter Exchange) | Cola donde caen las tareas que fallaron repetidamente, para inspección humana.                                 |
| RTO / RPO                  | Tiempo máximo de recuperación / pérdida máxima de datos aceptable ante un desastre.                            |
| DPIA                       | Análisis de impacto en protección de datos, obligatorio por el tratamiento biométrico.                         |
| Twelve-factor              | Principios para apps portables y escalables que facilitan la migración a Kubernetes.                           |
| Threat model               | Análisis de qué amenazas se mitigan y cuáles se aceptan, con qué nivel de garantía.                            |

## PARTE VI

# Recomendaciones de implementación - Argentina

---

Marco legal argentino de datos biométricos, opciones de liveness con estándar ISO/IEC 30107-3, y la tecnología necesaria para el funcionamiento esperado del proctoring.

## A1. Implementación en Argentina: marco legal y operativo

*Recomendaciones específicas para desplegar el proctoring bajo el marco normativo argentino de protección de datos, con foco en el tratamiento de datos biométricos. Esta sección traduce el principio de "privacidad por diseño" a las obligaciones concretas del país.*

### AVISO

Esta sección resume el marco aplicable a mayo de 2026 con fines de planificación; no constituye asesoramiento legal. El área legal y de protección de datos de la institución debe validar cada punto y completar el DPIA antes del desarrollo. El marco está en proceso de reforma, por lo que el diseño debe anticipar el estándar más exigente.

### A1.1 Norma aplicable y autoridad de control

El tratamiento se rige por la **Ley 25.326 de Protección de Datos Personales** (habeas data), con jerarquía constitucional desde la reforma de 1994 (art. 43), reglamentada por el Decreto 1558/2001 y supervisada por la **Agencia de Acceso a la Información Pública (AAIP)** como autoridad de control. Argentina ratificó además el **Convenio 108+** del Consejo de Europa, lo que refuerza la alineación con estándares internacionales. La rige también, de forma supletoria, el derecho a la privacidad del art. 19 de la Constitución.

### A1.2 Estado de la reforma (señal de diseño)

Existen proyectos de reforma integral de la Ley 25.326 en el Congreso, inspirados en el anteproyecto de la AAIP y alineados con el RGPD europeo y la LGPD brasileña. Sus novedades relevantes para este proyecto son: incorporación explícita de los **datos biométricos** como categoría definida, principios de **responsabilidad proactiva y demostrada** y **privacidad por diseño y por defecto**, nuevas bases legales (como el interés legítimo), y derechos de **portabilidad** y de **oposición a decisiones automatizadas**. Aunque la reforma no esté sancionada al momento de este documento, la recomendación es **diseñar contra el estándar reformado**: hacerlo hoy evita retrabajo y posiciona a la institución por delante del cambio normativo.

### A1.3 ¿Los embeddings faciales son "datos sensibles"?

Este es el punto jurídico más delicado y debe resolverse con el área legal. Bajo la **Resolución AAIP 4/2019** (Anexo I, criterio 4), en Argentina los datos biométricos se consideran **sensibles únicamente cuando pueden revelar información adicional cuyo uso resulte potencialmente discriminatorio** para el titular (por ejemplo, origen étnico o datos de salud). Esto difiere del RGPD, donde el dato biométrico usado para identificar unívocamente a una persona es sensible por definición.

## RECOMENDACIÓN DE DISEÑO

Aunque la interpretación local podría no calificar el embedding como "sensible" en todos los casos, la recomendación es **tratarlo como sensible por defecto** y aplicar "responsabilidad reforzada": es la postura más segura, anticipa la reforma, y es coherente con la privacidad por diseño que el proyecto ya adopta. El costo de sobre-proteger es bajo; el de sub-proteger, alto.

## A1.4 Base legal del tratamiento

La Ley 25.326 (art. 5) toma el **consentimiento** del titular como base general de licitud, con excepciones. La recomendación práctica para el caso académico:

### BASES LEGALES Y SU APLICACIÓN AL PROCTORING

| BASE                                    | APLICACIÓN RECOMENDADA                                                                                                                                                                                           |
|-----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Consentimiento informado</b>         | Base principal para la captura biométrica. Debe ser libre, expreso e informado, con acción afirmativa (no casillas premarcadas), y registrado con timestamp y hash, como ya prevé el sistema.                    |
| <b>Relación contractual / académica</b> | Parte del tratamiento puede apoyarse en la relación institución-estudiante, pero NO debe usarse para forzar consentimiento biométrico: el consentimiento debe poder negarse sin perder el derecho a rendir.      |
| <b>Alternativa sin biometría</b>        | Se recomienda ofrecer una vía alternativa de verificación de identidad (p. ej., proctor humano en vivo) para quien no consienta el tratamiento biométrico, de modo que el consentimiento sea genuinamente libre. |

## A1.5 Lección de la jurisprudencia: el caso SRFP

El **Sistema de Reconocimiento Facial de Prófugos (SRFP)** de la Ciudad de Buenos Aires fue objeto de amparos colectivos que cuestionaron la falta de marco claro sobre la base de datos, el riesgo de errores de identificación, la ausencia de controles independientes y la posible extralimitación de finalidad. Los tribunales fijaron límites bajo las pautas de **legalidad, necesidad y proporcionalidad**, y ordenaron suspender o rediseñar el sistema. La lección directa para este proyecto:

- **Finalidad acotada y declarada:** los datos biométricos se usan solo para verificar identidad en el examen, nunca para otros fines.
- **Proporcionalidad:** el nivel L2.5 y la ausencia de video continuo son, además de buenas decisiones técnicas, argumentos de proporcionalidad jurídica.
- **Control independiente y trazabilidad:** el audit log inmutable responde directamente a la objeción de "ausencia de controles sobre el acceso y uso".
- **No reutilización:** prohibición explícita de cruzar la base con cualquier otra finalidad (vigilancia, marketing, cesión).

## A1.6 Estudiantes menores de edad

Si la institución evalúa a personas menores de 18 años, el consentimiento debe prestarlo quien ejerce la responsabilidad parental, con consideraciones reforzadas. La recomendación es identificar tempranamente

si hay población menor de edad y, de haberla, tratar su caso con un flujo de consentimiento y retención diferenciado, validado por el área legal.

### A1.7 Registro, DPIA y derechos del titular

La ley vigente exige inscribir las bases de datos en el **Registro Nacional de Bases de Datos** de la AAIP (la reforma prevé eliminar esta obligación formal, pero hoy sigue vigente). El proyecto debe además producir una **Evaluación de Impacto en Protección de Datos (DPIA)** antes del desarrollo —ya contemplada en la Fase 0— y garantizar los derechos del titular (acceso, rectificación, supresión, y, anticipando la reforma, portabilidad y oposición a decisiones automatizadas). El derecho de oposición a decisiones automatizadas refuerza la decisión de diseño de que **ninguna sanción sea automática**: el sistema ya cumple este principio por arquitectura.

### A1.8 Síntesis de obligaciones para el despliegue argentino

#### CHECKLIST DE CUMPLIMIENTO PARA ARGENTINA

| OBLIGACIÓN                                                        | ESTADO EN EL DISEÑO ACTUAL                                                          |
|-------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| Consentimiento libre, expreso e informado                         | Cubierto (flujo de consentimiento con hash). Agregar vía alternativa sin biometría. |
| Tratar embeddings como dato sensible (responsabilidad reforzada)  | Recomendado: cifrado at-rest ya previsto; formalizar la clasificación.              |
| Finalidad acotada y no reutilización                              | Cubierto por diseño; formalizar en política y en el Acuerdo de Nivel de Proctoring. |
| Proporcionalidad (L2.5, sin video continuo)                       | Cubierto por arquitectura.                                                          |
| Audit log y control de accesos independiente                      | Cubierto (audit log inmutable).                                                     |
| DPIA previa al desarrollo                                         | Previsto en Fase 0.                                                                 |
| Inscripción de la base ante la AAIP                               | Acción pendiente del área legal.                                                    |
| Derechos del titular (incl. oposición a decisiones automatizadas) | Cubierto: revisión humana obligatoria; portabilidad a implementar.                  |
| Retención y supresión verificable                                 | Previsto (retención configurable + eliminación al egreso).                          |
| Soberanía de datos (datos en el país)                             | Cubierto: despliegue self-hosted en infraestructura institucional.                  |

## A2. Opciones de liveness (detección de prueba de vida)

La verificación de identidad solo es tan fuerte como su liveness. Esta sección compara los enfoques disponibles, el estándar internacional de evaluación, las amenazas actuales (deepfakes e inyección) y una recomendación concreta para el proyecto.

### A2.1 Por qué el liveness es el eslabón crítico

Sin liveness, el bypass de la verificación facial es trivial: basta mostrar a la cámara una foto o un video del compañero. El liveness confirma que **frente a la cámara hay una persona viva y presente**, no un artefacto. Es, junto con la cadena de custodia, una de las dos piezas que separan "recolectar una selfie" de "verificar identidad de forma defendible".

**EN PALABRAS SIMPLES**

El reconocimiento facial responde "¿esta cara coincide con la registrada?". El liveness responde la pregunta previa e imprescindible: "¿esto es una persona real ahora mismo, o una foto/video/máscara?". Sin lo segundo, lo primero se engaña fácil.

### A2.2 Enfoques: pasivo vs. activo

#### COMPARACIÓN DE ENFOQUES DE LIVENESS

| ENFOQUE                      | CÓMO FUNCIONA                                                                                                                                                      | VENTAJAS                                                                       | DESVENTAJAS                                                                                     |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>Pasivo</b>                | Analiza una imagen o video corto buscando "artefactos de spoofing" (moiré de pantalla, bordes de papel, falta de textura/profundidad) sin pedir acción al usuario. | Sin fricción; rápido; mejor experiencia; difícil de "ensayar" por el atacante. | Vulnerable a deepfakes de alta fidelidad e inyección si no se complementa.                      |
| <b>Activo</b>                | Pide una acción al usuario (parpadear, sonreír, girar la cabeza, seguir un punto) y verifica que ocurra de forma natural.                                          | Confirma interacción en tiempo real; intuitivo de explicar.                    | Más fricción y ansiedad; un deepfake en tiempo real puede ejecutar la acción ("puppet master"). |
| <b>Híbrido (recomendado)</b> | Combina análisis pasivo continuo con uno o dos retos activos aleatorios.                                                                                           | Sube el costo del ataque; equilibra seguridad y experiencia.                   | Algo más de complejidad de implementación.                                                      |

### A2.3 El estándar de evaluación: ISO/IEC 30107-3

La calidad de un liveness no se declara, se **mide** contra el estándar **ISO/IEC 30107-3** de *Presentation Attack Detection (PAD)*, evaluado por laboratorios acreditados (iBeta/NVLAP, TÜV). Sus dos métricas clave:

- **APCER** (Attack Presentation Classification Error Rate): proporción de ataques que el sistema clasifica erróneamente como legítimos. Cuanto más bajo, mejor.
- **BPCER** (Bona Fide Presentation Classification Error Rate): proporción de personas reales rechazadas erróneamente. Es el equivalente al "falso rechazo" que afecta la experiencia.

NIVELES DE CERTIFICACIÓN PAD (ISO/IEC 30107-3)

| NIVEL   | QUÉ ATAQUES CUBRE                                                                                                                     |
|---------|---------------------------------------------------------------------------------------------------------------------------------------|
| Nivel 1 | Ataques de presentación básicos y de bajo costo: fotos impresas, fotos en pantalla, videos de reproducción.                           |
| Nivel 2 | Ataques de costo medio: máscaras de mediana sofisticación, artefactos mejor contruidos. Es el umbral comercial razonable.             |
| Nivel 3 | Ataques de alto costo: máscaras de silicona hiperrealistas hechas a medida y entornos controlados. Muy pocos proveedores lo alcanzan. |

A2.4 La amenaza moderna: deepfakes e inyección de cámara

EL CAMBIO DE PARADIGMA DE AMENAZA (2024–2026)

La amenaza ya no es solo el ataque de presentación (mostrar algo a la cámara). Es la **inyección de cámara (camera pipe injection)**: el atacante *evita la cámara física* e inyecta video sintético —un deepfake en tiempo real— directamente en el flujo de datos de la aplicación. Un deepfake "puppet master" puede ejecutar los retos activos (parpadear, girar) en vivo, dejando ciega a la verificación. La industria reportó incrementos de cientos por ciento en ataques de face-swap e inyección en este período.

Implicación honesta para el proyecto: **ningún liveness que corra en el navegador del estudiante puede garantizar inmunidad a la inyección**, porque el cliente es manipulable por definición (coherente con el límite del paradigma web ya declarado). La defensa realista combina liveness + detección de cámara virtual + re-inferencia server-side + verificación continua + revisión humana.

A2.5 Opciones concretas para el proyecto

Coherente con la soberanía de datos y el self-hosting, se priorizan opciones que corran on-premise. Tres caminos:

OPCIONES DE IMPLEMENTACIÓN DE LIVENESS

| OPCIÓN                                          | DESCRIPCIÓN                                                                                                                                                                            | CUÁNDO CONVIENE                                                                                                                                |
|-------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. Heurístico propio en navegador (base actual) | Liveness activo liviano con Face Mesh: parpadeo involuntario, micro-movimientos y profundidad estimada por la geometría 3D de los 468 landmarks.                                       | MVP y casos de impacto medio. Costo cero de licencias; total soberanía; suficiente para disuadir al oportunista, no al adversario sofisticado. |
| 2. Modelo open-source self-hosted               | Integrar un modelo pasivo entrenado (p. ej., enfoques tipo Silent-Face-Anti-Spoofing, DeePixBiS u otros con licencia compatible), ejecutado server-side sobre el clip de verificación. | Fase 2, para subir robustez sin costo de licencia ni salida de datos. Requiere validar licencia, calidad y mantenimiento del proyecto.         |



| OPCIÓN                                  | DESCRIPCIÓN                                                                                | CUÁNDO CONVIENE                                                                                                                                                                                |
|-----------------------------------------|--------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>3. SDK comercial certificado PAD</b> | SDK con certificación ISO 30107-3 Nivel 2/3 (varios ofrecen despliegue on-premise/Docker). | Si la institución eleva el nivel de impacto de los exámenes o necesita defensa contra deepfakes/inyección con garantía certificada. Implica costo y due diligence de privacidad del proveedor. |

## A2.6 Recomendación

### RECOMENDACIÓN DE ARQUITECTURA — LIVENESS

**Enfoque escalonado.** Para el MVP (Fase 1): liveness **híbrido propio** (pasivo + uno o dos retos activos aleatorios) en el navegador, reforzado con **re-inferencia server-side** sobre el clip y **detección de cámara virtual**. Para Fase 2: incorporar un **modelo pasivo open-source self-hosted** que corra en el servidor sobre el clip de verificación, elevando la robustez sin comprometer la soberanía. Reservar el **SDK comercial certificado (Nivel 2+)** como opción para cuando —y solo si— la institución decida elevar el nivel de impacto de los exámenes, lo que dispararía la revisión del Acuerdo de Nivel de Proctoring.

En todos los casos, mantener expectativas realistas: el liveness eleva fuertemente el costo del fraude de identidad, pero la verificación continua y la revisión humana siguen siendo la red de seguridad, no un adorno.

## A3. Tecnología necesaria para el funcionamiento esperado

Qué se necesita —en el cliente, en el servidor y en el dispositivo del estudiante— para que el proctoring funcione como se espera, partiendo de la base arquitectónica ya definida y agregando las recomendaciones de detección, liveness y anti-fraude actuales.

### A3.1 Lado cliente (navegador del estudiante)

#### TECNOLOGÍA EN EL CLIENTE

| COMPONENTE            | TECNOLOGÍA / ROL                                                                                                  | RECOMENDACIÓN ACTUALIZADA                                                                                                                                  |
|-----------------------|-------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Detección de visión   | MediaPipe (BlazeFace para Face Detection, Face Mesh con 468 landmarks, Pose) sobre WebAssembly, en un Web Worker. | Usar el delegado <b>GPU</b> de las MediaPipe Tasks; evaluar <b>WebGPU</b> donde el navegador lo soporte para mayor rendimiento, con fallback a WebGL/WASM. |
| Liveness              | Detección de prueba de vida en la verificación inicial y continua.                                                | Híbrido (pasivo + retos activos) según la sección A2.                                                                                                      |
| Captura multimedia    | getUserMedia (cámara/mic), Screen Capture API (pantalla y detección de monitores).                                | Declarar permisos con claridad; degradación graceful si el dispositivo no cumple.                                                                          |
| Buffer resiliente     | IndexedDB como buffer circular de eventos ante cortes de red.                                                     | Mantener; reenvío ordenado con last_event_id.                                                                                                              |
| Anti-tampering pasivo | CSP, SRI, fingerprint del entorno, heartbeats firmados, detección de DevTools y de <b>cámara virtual</b> .        | Reforzar la detección de cámara virtual: es la primera línea contra inyección de deepfakes.                                                                |
| Transporte            | HTTPS, WebSocket (WSS), subida directa a storage por URL firmada.                                                 | Mantener.                                                                                                                                                  |

### A3.2 Lado servidor (infraestructura institucional)

#### TECNOLOGÍA EN EL SERVIDOR

| CAPA              | TECNOLOGÍA                                                                                                          |
|-------------------|---------------------------------------------------------------------------------------------------------------------|
| API y tiempo real | FastAPI (ASGI/uvicorn) escalado horizontalmente; REST versionada + WebSockets; Nginx con TLS 1.3 y sticky sessions. |
| Identidad         | Keycloak (OAuth2/OIDC/SAML) federado con el directorio institucional; MFA para roles sensibles.                     |

| CAPA                                 | TECNOLOGÍA                                                                                                     |
|--------------------------------------|----------------------------------------------------------------------------------------------------------------|
| Persistencia                         | PostgreSQL (dominio) + TimescaleDB (eventos como hypertable, compresión y agregados continuos).                |
| Mensajería                           | Redis (caché + Pub/Sub no crítico) y RabbitMQ con quorum queues (tareas críticas: re-inferencia, firma).       |
| Procesamiento asíncrono              | Celery workers para re-inferencia server-side, firma de evidencia, reportes.                                   |
| Evidencia                            | MinIO/S3 con Object Lock (WORM), cifrado at-rest, versionado.                                                  |
| Re-inferencia y liveness server-side | Modelos de visión y, en Fase 2, modelo de liveness pasivo open-source ejecutado sobre el clip de verificación. |
| Observabilidad                       | Prometheus, Loki, Tempo/OpenTelemetry, Grafana.                                                                |

### A3.3 Requisitos del dispositivo del estudiante

El funcionamiento esperado depende de que el dispositivo del estudiante cumpla un perfil mínimo. La detección de capacidad al inicio debe verificarlo y, si no se cumple, comunicar el problema con claridad o escalar a un proctor en lugar de generar falsos positivos.

#### PERFIL MÍNIMO Y RECOMENDADO DEL DISPOSITIVO

| RECURSO                 | MÍNIMO                                                  | RECOMENDADO                                     |
|-------------------------|---------------------------------------------------------|-------------------------------------------------|
| Navegador               | Últimas 2 versiones de Chrome, Edge, Firefox o Safari   | Chrome/Edge recientes (mejor soporte de WebGPU) |
| Cámara                  | 720p                                                    | 1080p con buena gestión de poca luz             |
| Micrófono               | Funcional (para fase de audio)                          | Con reducción de ruido                          |
| CPU/GPU                 | Capaz de sostener Face Detection + Face Mesh a 5–10 fps | GPU con WebGL/WebGPU para Pose simultáneo       |
| Memoria                 | 4 GB                                                    | 8 GB                                            |
| Conexión                | 10 Mbps bajada / 2 Mbps subida, estable                 | 20/5 Mbps                                       |
| Iluminación del entorno | Frontal, sin contraluz fuerte                           | Difusa y uniforme                               |

### A3.4 Lo que la tecnología SÍ habilita y lo que NO

#### ✓ El stack habilita

Detección local a escala sin infraestructura central de video; verificación de identidad con liveness; evidencia con cadena de custodia criptográfica; observabilidad completa; soberanía total de los datos; portabilidad a Kubernetes.

### X La tecnología no resuelve por sí sola

La inmunidad total a deepfakes/inyección en un cliente no controlado; la detección de medios fuera de cámara; la capacidad de revisión humana (es un recurso de la institución, no del software); la calidad del dispositivo y la conexión del estudiante.

## A3.5 Mapa de implementación por fase

### QUÉ TECNOLOGÍA ENTRA EN CADA FASE

| FASE         | TECNOLOGÍA QUE SE INCORPORA                                                                                                                                                                 |
|--------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Fase 1 (MVP) | MediaPipe en navegador (GPU), liveness híbrido propio, re-inferencia server-side, detección de cámara virtual, cadena de custodia completa, todo el stack de backend y observabilidad base. |
| Fase 2       | Modelo de liveness pasivo open-source self-hosted, análisis de audio, evaluación de WebGPU, calibración de umbrales con datos reales, integración con el LMS.                               |
| Fase 3       | Migración a Kubernetes, multi-tenancy, y —si el nivel de impacto lo justifica— evaluación de SDK comercial de liveness certificado PAD Nivel 2+.                                            |

### CIERRE DE LAS RECOMENDACIONES

La base arquitectónica ya definida es sólida y apropiada para el funcionamiento esperado. Las recomendaciones de esta sección no la reemplazan: la **completan** con tres refuerzos alineados a la realidad de 2026 —liveness escalonado con estándar ISO 30107-3 como referencia, defensa explícita contra inyección de cámara, y cumplimiento argentino tratando el embedding como dato sensible por defecto—. Todas son coherentes con los principios ya adoptados: privacidad por diseño, soberanía de datos, honestidad sobre los límites y revisión humana como red de seguridad.

## A4. Análisis arquitectónico independiente y arquitectura recomendada

Esta sección no se limita a describir la arquitectura del SAD original: la somete a un análisis crítico independiente, la compara con alternativas del estado del arte (2026) y concluye en una arquitectura recomendada con su justificación. Pensada como base de conocimiento para el desarrollo, distingue explícitamente qué decisiones conviene conservar, cuáles revisar y cuáles cambiar.

### MARCO DE LA EVALUACIÓN

Ninguna arquitectura es "la mejor" en abstracto: lo es respecto de qué se optimiza. Aquí se evalúa contra **seis factores** ponderados según el contexto del proyecto: (1) escala objetivo (700 concurrentes), (2) costo total, (3) soberanía y privacidad, (4) **complejidad operacional** —crítica, porque el equipo es acotado—, (5) robustez y defensibilidad, y (6) time-to-market. El SAD original optimiza fuertemente escala-barata + soberanía; tiende a *sub-ponderar* la complejidad operacional, que es el principal punto de revisión.

### A4.1 Veredicto por decisión: conservar, revisar o cambiar

#### EVALUACIÓN CRÍTICA DE LAS DECISIONES DEL SAD

| DECISIÓN DEL SAD                            | VEREDICTO | ANÁLISIS INDEPENDIENTE                                                                                                                                                                                                                                                                                                                                                                                                          |
|---------------------------------------------|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IA de visión en el navegador (client-heavy) | Conservar | Decisión correcta y no negociable para esta escala. Centralizar inferencia de 700 streams sería 10–50× más caro. Es el acierto estructural del diseño.                                                                                                                                                                                                                                                                          |
| PostgreSQL + TimescaleDB                    | Conservar | Excelente encaje para el patrón de escritura intensa de eventos. Hypertables, compresión y agregados continuos son exactamente lo que se necesita.                                                                                                                                                                                                                                                                              |
| Revisión humana / no sanción automática     | Conservar | Correcto en lo técnico, lo ético y lo legal (anticipa el derecho de oposición a decisiones automatizadas).                                                                                                                                                                                                                                                                                                                      |
| Keycloak como IdP                           | Conservar | Implementar identidad a mano es de los errores más caros. Keycloak es la opción madura y soberana.                                                                                                                                                                                                                                                                                                                              |
| Cadena de custodia + WORM + audit log       | Conservar | Es lo que hace la evidencia defendible. Mantener sin cambios.                                                                                                                                                                                                                                                                                                                                                                   |
| MediaPipe como motor de visión              | Revisar   | Maduro y con modelos validados, pero Google ha reorganizado/deprecado partes del proyecto repetidamente. <b>ONNX Runtime Web</b> es la tendencia ascendente: open standard, control total del pipeline, soporte WebGPU creciente y portabilidad de modelos. Recomendación: MediaPipe para el MVP (time-to-market), con <b>abstracción del motor de inferencia</b> para poder migrar a ONNX Runtime Web sin reescribir el resto. |

| DECISIÓN DEL SAD                                       | VEREDICTO             | ANÁLISIS INDEPENDIENTE                                                                                                                                                                                          |
|--------------------------------------------------------|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RabbitMQ + Redis + Celery (triple stack de mensajería) | Revisar / simplificar | Es el punto más sobre-dimensionado. Tres piezas de infraestructura de mensajería para 700 concurrentes es complejidad operacional alta para un equipo acotado. Ver A4.2.                                        |
| WebSockets con sticky sessions                         | Revisar               | Funciona, pero acopla el escalado. Alternativas: <b>SSE</b> (server-sent events) para el panel del proctor —unidireccional, más simple—, y un backplane de Redis para no depender de sticky sessions. Ver A4.3. |
| Liveness propio en navegador                           | Reforzar              | Es el eslabón más débil frente a deepfakes/inyección (sección A2). Mantener para el MVP pero con re-inferencia server-side y ruta a modelo certificado.                                                         |
| Docker Compose inicial → Kubernetes                    | Conservar             | Pragmatismo correcto. Arrancar simple y migrar cuando la escala lo justifique, con código twelve-factor desde el día uno.                                                                                       |

## A4.2 El punto crítico: simplificar la mensajería

El SAD usa Redis (Pub/Sub + caché) + RabbitMQ (tareas críticas) + Celery. Cada pieza añade superficie de operación, monitoreo, backup y modos de falla. La pregunta honesta es: **¿la escala objetivo justifica esa complejidad?** El análisis del estado del arte 2026 sugiere que, para 700 concurrentes, hay opciones más simples sin perder garantías:

### OPCIONES DE MENSAJERÍA COMPARADAS

| OPCIÓN                                                                | COMPLEJIDAD | DURABILIDAD               | CUÁNDO CONVIENE                                                                                                                                                                             |
|-----------------------------------------------------------------------|-------------|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>A — Postgres como cola</b> (pg-boss / SKIP LOCKED) + LISTEN/NOTIFY | Muy baja    | Alta (ACID)               | Recomendada para el MVP. Elimina RabbitMQ y Celery: una pieza menos que operar, durabilidad transaccional, y la base de datos ya está. Producción-ready para cargas "procesá este trabajo". |
| <b>B — Redis Streams + BullMQ</b>                                     | Media       | Media (depende de config) | Si ya se usa Redis para caché/fan-out y se quiere una sola pieza para todo. Cuidado con la memoria y la evicción.                                                                           |
| <b>C — RabbitMQ quorum + Celery</b> (SAD original)                    | Alta        | Muy alta (Raft)           | Justificable solo si la durabilidad de la firma de evidencia exige garantías de consenso y el volumen crece mucho. Para 700, probablemente sobra al inicio.                                 |
| <b>D — NATS JetStream</b>                                             | Media       | Alta                      | Excelente si en el futuro se requiere mensajería distribuida de baja latencia multi-nodo. Hoy, innecesario.                                                                                 |

### RECOMENDACIÓN

Para el MVP, **Opción A (Postgres como cola)**: arranca con *una* tecnología de datos y mensajería en lugar de tres. Mantener Redis solo si el fan-out en tiempo real al panel realmente lo exige (ver A4.3). Reservar RabbitMQ/NATS para una fase posterior *si y solo si* el monitoreo demuestra que Postgres es el cuello de botella. Esto reduce el costo operacional, el riesgo y el time-to-market sin sacrificar durabilidad de la evidencia.

## A4.3 Transporte en tiempo real: WebSockets, SSE y fan-out

El SAD usa WebSockets con sticky sessions en todos los canales. Distinción que conviene hacer:

- **Canal del estudiante** (eventos, heartbeats, comandos): es bidireccional → WebSocket es apropiado. Conservar.
- **Panel del proctor/revisor** (recibe flujo de eventos): es esencialmente unidireccional servidor → cliente → **SSE (server-sent events)** es más simple, reconecta solo, y evita parte de la complejidad de WebSocket. Recomendado evaluar.
- **Sticky sessions**: para no acoplar el escalado, usar un **backplane** (Redis Pub/Sub o Postgres LISTEN/NOTIFY) que distribuya eventos entre instancias, de modo que cualquier instancia pueda servir a cualquier panel. Esto elimina la fragilidad del "hash que concentra conexiones".

## A4.4 Arquitectura recomendada (síntesis)

La siguiente es la arquitectura que este análisis recomienda como base de desarrollo: conserva los aciertos estructurales del SAD, simplifica la mensajería, abstrae el motor de visión y refuerza el liveness. Está organizada en tres niveles de madurez para alinear complejidad con necesidad real.

### Nivel 1 — MVP (Fase 1): simple, soberano, suficiente



Diferencias clave con el SAD: **se elimina RabbitMQ, Celery y (opcionalmente) Redis** en favor de Postgres como cola; el panel usa **SSE**; el motor de visión está **abstraído** tras una interfaz para poder cambiarlo.

### Nivel 2 — Crecimiento (Fase 2): introducir piezas solo cuando el dato lo pida

- **Redis** como caché y backplane de fan-out, si el volumen de eventos al panel lo justifica (medido, no asumido).
- **Modelo de liveness pasivo open-source** server-side sobre el clip de verificación.
- **ONNX Runtime Web** reemplazando MediaPipe si se necesitan modelos propios o mayor control (la abstracción del Nivel 1 lo hace barato).
- **Réplica de lectura** de Postgres para descargar consultas de paneles y reportes.

Nivel 3 — Escala / multi-institución (Fase 3): especialización justificada

- **Kubernetes** con autoescalado (el código ya es twelve-factor).
- **Mensajería dedicada** (RabbitMQ quorum o NATS JetStream) *solo si* Postgres-como-cola se vuelve el cuello de botella demostrado.
- **Multi-tenancy** con aislamiento por institución.
- **SDK de liveness certificado PAD Nivel 2+** si se eleva el nivel de impacto de los exámenes.

A4.5 Comparación: SAD original vs. arquitectura recomendada

DIFERENCIAS Y SU IMPACTO

| ASPECTO                | SAD ORIGINAL                                                                                                                                         | ARQUITECTURA RECOMENDADA                                                                                                   |
|------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Mensajería             | Redis + RabbitMQ + Celery (3 piezas)                                                                                                                 | Postgres como cola en el MVP; piezas dedicadas solo si el dato lo justifica. <b>Menos complejidad operacional y costo.</b> |
| Fan-out al panel       | WebSocket + sticky sessions                                                                                                                          | SSE + backplane. <b>Menos acoplamiento de escalado.</b>                                                                    |
| Motor de visión        | MediaPipe (acoplado)                                                                                                                                 | Interfaz abstraída; MediaPipe hoy, ONNX Runtime Web mañana. <b>Menos lock-in.</b>                                          |
| Liveness               | Heurístico en cliente                                                                                                                                | Híbrido + re-inferencia server-side + ruta a certificado. <b>Más robusto.</b>                                              |
| Filosofía de escalado  | Construir para la escala desde el inicio                                                                                                             | Empezar simple, instrumentar, escalar con evidencia. <b>Menos riesgo de sobre-ingeniería.</b>                              |
| Aciertos estructurales | <b>Idénticos y conservados:</b> IA en cliente, Postgres+TimescaleDB, cadena de custodia, Keycloak, revisión humana, observabilidad de primera clase. |                                                                                                                            |

A4.6 Principio rector para el desarrollo

LA REGLA QUE DEBE GUIAR LA BASE DE CONOCIMIENTO

"Empezá con la arquitectura más simple que cumpla los requisitos no funcionales, instrumentá todo, y agregá complejidad solo cuando una métrica lo demuestre necesario." El SAD original es una arquitectura de destino válida, pero introducirla completa desde el día uno es sobre-ingeniería para 700 concurrentes y un equipo acotado. La arquitectura recomendada llega al mismo destino por un camino de menor riesgo: conserva todos los aciertos estructurales y de defensibilidad, pero difiere las piezas de alta complejidad operacional hasta que el crecimiento real las justifique. Esto reduce costo, acelera el time-to-market y —lo más importante— hace el sistema operable por el equipo que efectivamente lo va a sostener.



#### CÓMO USAR ESTA RECOMENDACIÓN

Esta sección expresa un análisis técnico fundamentado, no un dogma. Las decisiones finales deben validarse con una **prueba de concepto** en la Fase 0/1 que mida el comportamiento real de Postgres-como-cola y SSE bajo carga simulada de 700 concurrentes. Si la PoC muestra límites, las opciones del SAD original (RabbitMQ, WebSockets) siguen sobre la mesa como evolución natural —documentada en los ADRs— y no como retrabajo.